

PCI Scan Vulnerability Report

PCI Status

The following table highlights the overall compliance status and each individual system's compliance status. Following the table is a detailed report specifying each system and its specific vulnerabilities.

Overall PCI Status		FAIL
Live IP Address Scanned	Security Risk Rating	PCI Status
75.126.159.2		FAIL
75.126.159.3		FAIL

Report Summary	
Company:	Trainpetdog Limited
Hosts in account	3
Hosts scanned	3
Hosts active	2
Scan date	June 26, 2017
Report date	June 26, 2017

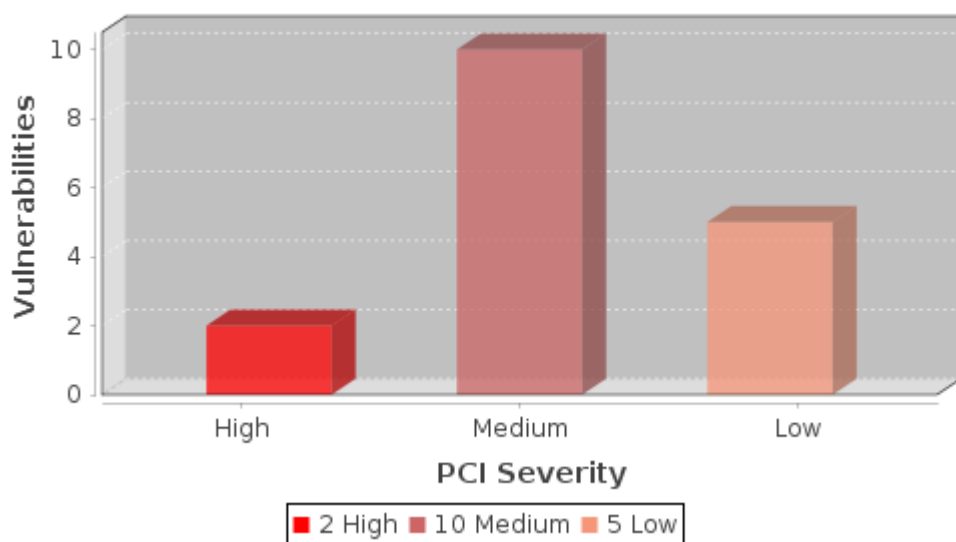
Summary of Vulnerabilities

Vulnerabilities total:	109	Security risk:		4
------------------------	-----	----------------	--	---

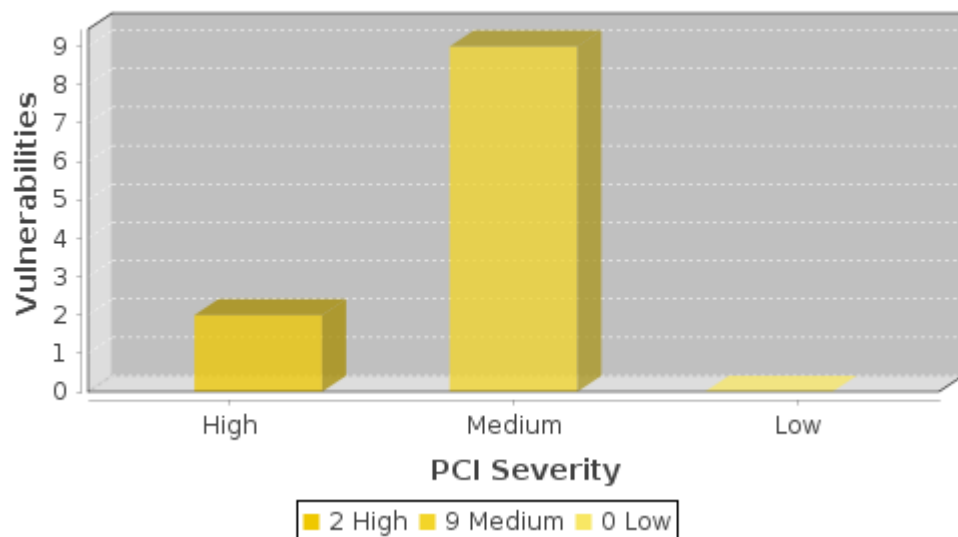
by Severity				
Severity	Confirmed	Potential	Information gathered	Total
5	0	2	0	2
4	0	3	0	3
3	4	4	4	12
2	10	2	12	24
1	3	0	65	68
Total	17	11	81	109

by PCI Severity			
PCI Severity	Confirmed	Potential	Total
High	2	2	4
Medium	10	9	19
Low	5	0	5
Total	17	11	28

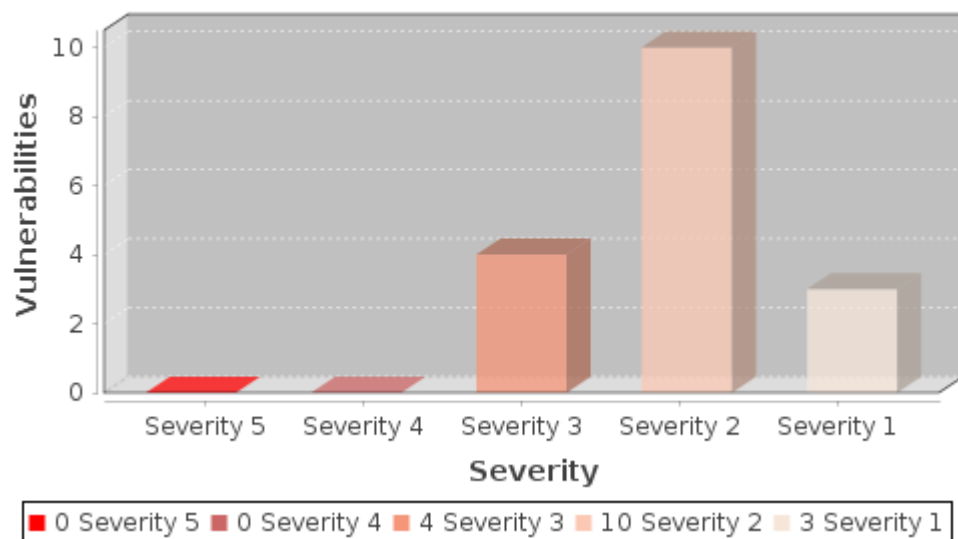
Vulnerabilities by PCI Severity

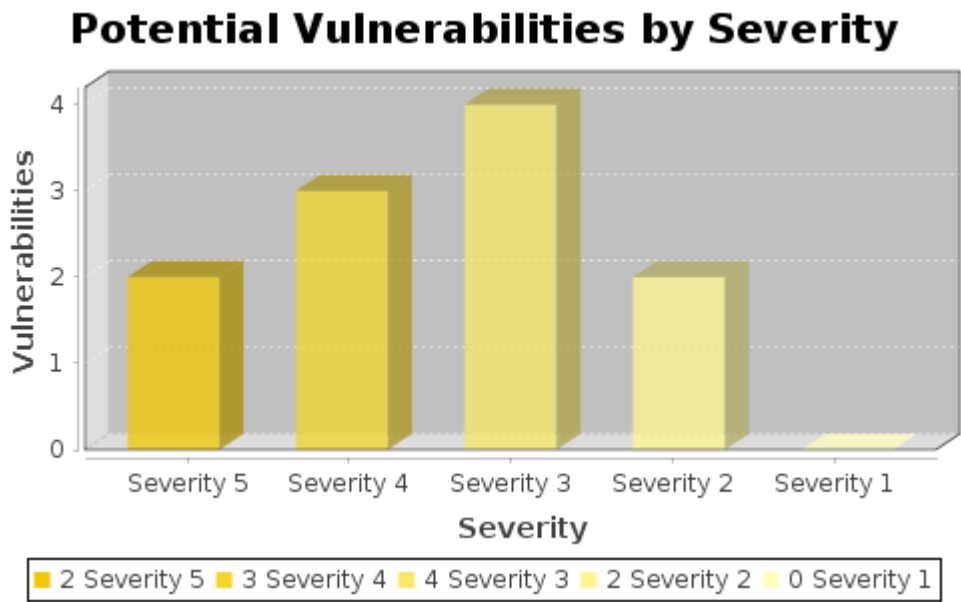


Potential Vulnerabilities by PCI Severity



Vulnerabilities by Severity





Detailed Results

75.126.159.2 (2.9f.7e4b.ip4.static.sl-reverse.com,)

Ubuntu / Tiny Core Linux / Linux 2.6.x

Vulnerabilities total:	48	Security risk:		5
------------------------	----	----------------	--	---

Vulnerabilities (4)

Hidden RPC Services

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

FAIL

The vulnerability is not included in the NVD.

VULNERABILITY DETAILS

CVSS Base Score: 5 AV:N/AC:L/Au:N/C:P/I:N/A:N

CVSS Temporal Score: 3.6 E:U/RL:W/RC:UC

Severity: 2

QID: 11

Category: RPC

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 1999-01-01 08:00:00.0

THREAT:

The Portmapper/Rpcbind listens on port 111 and stores an updated list of registered RPC services running on the server (RPC name, version and port number). It acts as a "gateway" for clients wanting to connect to any RPC daemon.

When the portmapper/rpcbind is removed or firewalled, standard RPC client programs fail to obtain the portmapper list. However, by sending carefully crafted packets, it's possible to determine which RPC programs are listening on which port. This technique is known as direct RPC scanning. It's used to bypass portmapper/rpcbind in order to find RPC programs running on a port (TCP or UDP ports). On Linux servers, RPC services are typically listening on privileged ports (below 1024), whereas on Solaris, RPC services are on temporary ports (starting with port 32700).

IMPACT:

Unauthorized users can build a list of RPC services running on the host. If they discover vulnerable RPC services on the host, they then can exploit them.

SOLUTION:

Firewalling the portmapper port or removing the portmapper service is not sufficient to prevent unauthorized users from accessing the RPC daemons. You should remove all RPC services that are not strictly required on this host.

RESULT:

Name	Program	Version	Protocol	Port
portmap	100000	2-4	tcp	111
/rpcbind				
portmap	100000	2-4	udp	693
/rpcbind				

UDP Constant IP Identification Field Fingerprinting Vulnerability

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

PASS

ASV Score = 0. The information obtained (i.e. operating system name) is not relevant to PCI.

VULNERABILITY DETAILS

CVSS Base Score: 5 AV:N/AC:L/Au:N/C:P/I:N/A:N

CVSS Temporal Score: 4.7 E:H/RL:U/RC:UR

Severity: 2 

QID: 82024

Category: TCP/IP

CVE ID: [CVE-2002-0510](#)

Vendor Reference: -

Bugtraq ID: [4314](#)

Last Update: 2008-05-07 18:23:49.0

THREAT:

The host transmits UDP packets with a constant IP Identification field. This behavior may be exploited to discover the operating system and approximate kernel version of the vulnerable system.

Normally, the IP Identification field is intended to be a reasonably unique value, and is used to reconstruct fragmented packets. It has been reported that in some versions of the Linux kernel IP stack implementation as well as other operating systems, UDP packets are transmitted with a constant IP Identification field of 0.

IMPACT:

By exploiting this vulnerability, a malicious user can discover the operating system and approximate kernel version of the host. This information can then be used in further attacks against the host.

SOLUTION:

We are not currently aware of any fixes for this issue.

RESULT:

IP_ID=0

TCP Sequence Number Approximation Based Denial of Service

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

PASS

The vulnerability is purely a denial-of-service (DoS) vulnerability.

VULNERABILITY DETAILS

CVSS Base Score: 5 AV:N/AC:L/Au:N/C:N/I:N/A:P
CVSS Temporal Score: 4.2 E:F/RL:T/RC:C
Severity: 2 
QID: 82054
Category: TCP/IP
CVE ID: [CVE-2004-0230](#)
Vendor Reference: -
Bugtraq ID: [10183](#)
Last Update: 2010-02-03 01:08:44.0

THREAT:

TCP provides stateful communications between hosts on a network. TCP sessions are established by a three-way handshake and use random 32-bit sequence and acknowledgement numbers to ensure the validity of traffic. A vulnerability was reported that may permit TCP sequence numbers to be more easily approximated by remote attackers. This issue affects products released by multiple vendors.

The cause of the vulnerability is that affected implementations will accept TCP sequence numbers within a certain range, known as the acknowledgement range, of the expected sequence number for a packet in the session. This is determined by the TCP window size, which is negotiated during the three-way handshake for the session. Larger TCP window sizes may be set to allow for more throughput, but the larger the TCP window size, the more probable it is to guess a TCP sequence number that falls within an acceptable range. It was initially thought that guessing an acceptable sequence number was relatively difficult for most implementations given random distribution, making this type of attack impractical. However, some implementations may make it easier to successfully approximate an acceptable TCP sequence number, making these attacks possible with a number of protocols and implementations.

This is further compounded by the fact that some implementations may support the use of the TCP Window Scale Option, as described in RFC 1323, to extend the TCP window size to a maximum value of 1 billion.

This vulnerability will permit a remote attacker to inject a SYN or RST packet into the session, causing it to be reset and effectively allowing for denial of service attacks. An attacker would exploit this issue by sending a packet to a receiving implementation with an approximated sequence number and a forged source IP address and TCP port.

There are a few factors that may present viable target implementations, such as those which depend on long-lived TCP connections, those that have known or easily guessed IP address endpoints and those implementations with easily guessed TCP source ports. It has been noted that Border Gateway Protocol (BGP) is reported to be particularly vulnerable to this type of attack, due to the use of long-lived TCP sessions and the possibility that some implementations may use the TCP Window Scale Option. As a result, this issue is likely to affect a number of routing platforms.

Another factor to consider is the relative difficulty of injecting packets into TCP sessions, as a number of receiving implementations will reassemble packets in order, dropping any duplicates. This may make some implementations more resistant to attacks than others.

It should be noted that while a number of vendors have confirmed this issue in various products, investigations are ongoing and it is likely that many other vendors and products will turn out to be vulnerable as the issue is investigated further.

IMPACT:

Successful exploitation of this issue could lead to denial of service attacks on the TCP based services of target hosts.

SOLUTION:

Please first check the results section below for the port number on which this vulnerability was detected. If that port number is known to be used for port-forwarding, then it is the backend host that is really vulnerable.

Various implementations and products including Check Point, Cisco, Cray Inc, Hitachi, Internet Initiative Japan, Inc (IIJ), Juniper Networks, NEC, Polycom, and Yamaha are currently undergoing review. Contact the vendors to obtain more information about affected products and fixes. [NISCC Advisory 236929 - Vulnerability Issues in TCP](#) details the vendor patch status as of the time of the advisory, and identifies resolutions and workarounds.

Refer to [US-CERT Vulnerability Note VU#415294](#) and [OSVDB Article 4030](#) to obtain a list of vendors affected by this issue and a note on resolutions (if any) provided by the vendor.

For Microsoft: Refer to [MS05-019](#) and [MS06-064](#) for further details.

For SGI IRIX: Refer to [SGI Security Advisory 20040905-01-P](#)

For SCO UnixWare 7.1.3 and 7.1.1: Refer to [SCO Security Advisory SCOSA-2005.14](#)

For Solaris (Sun Microsystems): The vendor has acknowledged the vulnerability; however a patch is not available. Refer to [Sun Microsystems, Inc. Information for VU#415294](#) to obtain additional details. Also, refer to [TA04-111A](#) for detailed mitigating strategies against these attacks.

For NetBSD: Refer to [NetBSD-SA2004-006](#)

For Cisco: Refer to [cisco-sa-20040420-tcp-ios.shtml](#).

For Red Hat Linux: There is no fix available.

Workaround:

The following BGP-specific workaround information has been provided.

For BGP implementations that support it, the TCP MD5 Signature Option should be enabled. Passwords that the MD5 checksum is applied to should be set to strong values and changed on a regular basis.

Secure BGP configuration instructions have been provided for Cisco and Juniper at these locations:

[Secure Cisco IOS BGP Template](#)

[JUNOS Secure BGP Template](#)

RESULT:

Tested on port 111 with an injected SYN/RST offset by 16 bytes.

ICMP Timestamp Request

PCI COMPLIANCE STATUS

PCI Severity Level:

LOW

PASS

The vulnerability is purely a denial-of-service (DoS) vulnerability.

VULNERABILITY DETAILS

CVSS Base Score:

CVSS Temporal Score:

Severity: 1 

QID: 82003

Category: TCP/IP

CVE ID: [CVE-1999-0524](#)

Vendor Reference: -

Bugtraq ID: -

Last Update: 2009-04-29 03:59:17.0

THREAT:

ICMP (Internet Control and Error Message Protocol) is a protocol encapsulated in IP packets. Its principal purpose is to provide a protocol layer able to inform gateways of the inter-connectivity and accessibility of other gateways or hosts. "ping" is a well-known program for determining if a host is up or down. It uses ICMP echo packets. ICMP timestamp packets are used to synchronize clocks between hosts.

IMPACT:

Unauthorized users can obtain information about your network by sending ICMP timestamp packets. For example, the internal systems clock should not be disclosed since some internal daemons use this value to calculate ID or sequence numbers (i.e., on SunOS servers).

SOLUTION:

You can filter ICMP messages of type "Timestamp" and "Timestamp Reply" at the firewall level. Some system administrators choose to filter most types of ICMP messages for various reasons. For example, they may want to protect their internal hosts from ICMP-based Denial Of Service attacks, such as the *Ping of Death* or *Smurf* attacks.

However, you should never filter **ALL** ICMP messages, as some of them ("Don't Fragment", "Destination Unreachable", "Source Quench", etc) are necessary for proper behavior of Operating System TCP/IP stacks.

It may be wiser to contact your network consultants for advice, since this issue impacts your overall network reliability and security.

RESULT:

Timestamp of host (network byte ordering): 17:18:11 GMT

Potential Vulnerabilities (8)

Statd Format Bug Vulnerability

PCI COMPLIANCE STATUS

PCI Severity Level:

HIGH

FAIL

VULNERABILITY DETAILS

CVSS Base Score: **10** AV:N/AC:L/Au:N/C:C/I:C/A:C
CVSS Temporal Score: **8.3** E:F/RL:OF/RC:C
Severity: **5** 
QID: 66040
Category: RPC
CVE ID: [CVE-2000-0666](#), [CVE-2000-0800](#)
Vendor Reference: [RHSA-2000:043](#)
Bugtraq ID: [1480](#)
Last Update: 2016-09-19 03:30:32.0

THREAT:

The rpc.statd program, which is part of the nfs-utils packages, is distributed with a number of popular Linux distributions. The rpc.statd server is an RPC server that implements the Network Status and Monitor RPC protocol. It's a component of the Network File System (NFS) architecture.

rpc.statd contains a format string vulnerability when calling the syslog() function. This vulnerability allows remote users to execute code as root. The logging code in rpc.statd uses the syslog() function to pass user-supplied data as the format string. A malicious user can construct a format string that injects executable code into the process address space and overwrites a function's return address, forcing the program to execute the code.

rpc.statd requires root privileges for opening it's network socket, but fails to drop these privileges later on. Therefore, code injected by the malicious user will execute with root privileges.

Debian, Red Hat and Connectiva have all released advisories on this matter. Presumably, any Linux distribution that runs the statd process is vulnerable, unless already patched for the problem.

IMPACT:

If successfully exploited, unauthorized users can execute remote commands as root.

SOLUTION:

For Red Hat Linux: Upgrade to the latest version of nfs-utils (0.1.9.1 or later), as listed in [RHSA-2000:043-02](#).

For Debian Linux: Upgrade to the latest version of nfs-utils (0.1.9.1 or later), as listed in [Debian Security Advisory 20000719a](#).

For other distributions: Contact your vendor for upgrade or patch information.

Patch:

Following are links for downloading patches to fix the vulnerabilities:

[RHSA-2000:043-03: Red Hat Linux 6.2](#)

RESULT:

N/A

Oracle MySQL Multiple Security Vulnerabilities

port 3306 / tcp

PCI COMPLIANCE STATUS

PCI Severity Level:

HIGH

FAIL

VULNERABILITY DETAILS

CVSS Base Score: 10 AV:N/AC:L/Au:N/C:C/I:C/A:C
CVSS Temporal Score: 7.4 E:POC/RL:OF/RC:UR
Severity: 5 
QID: 20021
Category: Database
CVE ID: [CVE-2016-5616](#), [CVE-2016-5617](#), [CVE-2016-6662](#), [CVE-2016-6663](#), [CVE-2016-6664](#)
Vendor Reference: [CVE-2016-6662](#), [CVE-2016-6663](#), [CVE-2016-6664](#)
Bugtraq ID: -
Last Update: 2016-11-11 06:39:28.0

THREAT:

Oracle MySQL is an open-source relational database management system (RDBMS).

CVE-2016-6662- A vulnerability exists in the mysqld_safe script which is used by many default installations/packages of MySQL as a wrapper to start the MySQL service process. This script is executed with root privileges and the main mysqld process lowers its privilege level to mysql user. An attacker could exploit this vulnerability by injecting a path to their malicious library within the config, pre-loading an arbitrary library and executing arbitrary code with root privileges when MySQL service is restarted.

CVE-2016-6663/CVE-2016-5616- A race condition was found in the way MySQL performed MyISAM engine table repair. A database user with shell access to the server running mysqld could use this flaw to change permissions of arbitrary files writable by the mysql system user.

CVE-2016-6664/CVE-2016-5617- A flaw was found in the way the mysqld_safe script handled creation of error log file. The mysql operating system user could use this flaw to escalate their privileges to root.

Affected Versions:

Oracle MySQL versions prior to 5.7.15, 5.6.33 and 5.5.52

IMPACT:

Successful exploitation could allow remote, unauthenticated attackers to execute arbitrary code with root privileges which would then allow them to fully compromise the server on which an affected version of MySQL is running.

SOLUTION:

MySQL releases following security fixes: [MySQL 5.5.52](#) [MySQL 5.6.33](#) [MySQL 5.7.15](#)

Workaround:

As a temporary workaround, administrators are advised to ensure that no mysql config files are owned by mysql users. They are also advised to create root-owned dummy my.cnf files if not in use.

Patch:

Following are links for downloading patches to fix the vulnerabilities:

[Oracle MySQL](#)

RESULT:

Oracle MySQL mysqld_safe remote code execution vulnerability detected. MySQL version: 5.5.47-0+deb7u1-log

Oracle MySQL January 2017 Critical Patch Update (CPUJAN2017)

port 3306 / tcp

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

FAIL

Automatic Failure: Open access to databases from the Internet

VULNERABILITY DETAILS

CVSS Base Score: 4.9 AV:N/AC:M/Au:S/C:P/I:N/A:P

CVSS Temporal Score: 3.8 E:POC/RL:OF/RC:C

Severity: 4 

QID: 20029

Category: Database

CVE ID: [CVE-2016-8318](#), [CVE-2016-8327](#), [CVE-2017-3238](#), [CVE-2017-3243](#), [CVE-2017-3244](#), [CVE-2017-3251](#), [CVE-2017-3256](#), [CVE-2017-3257](#), [CVE-2017-3258](#), [CVE-2017-3265](#), [CVE-2017-3273](#), [CVE-2017-3291](#), [CVE-2017-3312](#), [CVE-2017-3313](#), [CVE-2017-3317](#), [CVE-2017-3318](#), [CVE-2017-3319](#), [CVE-2017-3320](#)

Vendor Reference: [MySQL CPU January 2017](#)

Bugtraq ID: [95470](#), [95479](#), [95482](#), [95486](#), [95491](#), [95501](#), [95520](#), [95527](#), [95538](#), [95557](#), [95560](#), [95565](#), [95571](#), [95580](#), [95583](#), [95585](#), [95588](#), [95589](#)

Last Update: 2017-02-01 05:32:22.0

THREAT:

This Critical Patch Update contains 18 new security fixes for Oracle MySQL.

Affected Versions:

MySQL Server, version(s) 5.5.53 and prior, 5.6.34 and prior, 5.7.16 and prior

IMPACT:

Successful exploitation could allow an attacker to affect the confidentiality, integrity and availability of data on the target system.

SOLUTION:

Refer to vendor advisory [Oracle MySQL January 2017](#).

Patch:

Following are links for downloading patches to fix the vulnerabilities:

[Oracle MySQL January 2017](#)

RESULT:

Vulnerable MySQL server detected: 5.5.47-0+deb7u1-log

OpenSSH AES-GCM Cipher Remote Code Execution Vulnerability

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

FAIL

VULNERABILITY DETAILS

CVSS Base Score: 6 AV:N/AC:M/Au:S/C:P/I:P/A:P

CVSS Temporal Score: 4.4 E:U/RL:O/RC:C
Severity: 4 
QID: 42420
Category: General remote services
CVE ID: [CVE-2013-4548](#)
Vendor Reference: [gcmrekey.adv](#)
Bugtraq ID: [63605](#)
Last Update: 2015-06-17 03:30:21.0

THREAT:

OpenSSH (OpenBSD Secure Shell) is a set of computer programs providing encrypted communication sessions over a computer network using the SSH protocol.

A memory corruption vulnerability in post-authentication exists when the Advanced Encryption Standard (AES)-Galois/Counter Mode of Operation (GCM) cipher is used for the key exchange. When an AES-GCM cipher is used, the mm_newkeys_from_blob() function in monitor_wrap.c does not properly initialize memory for a MAC context data structure, allowing remote authenticated users to bypass intended ForceCommand and login-shell restrictions via packet data that provides a crafted callback address.

The new cipher was added only in OpenSSH 6.2, released on March 22, 2013.

Affected Software:

OpenSSH 6.2 and OpenSSH 6.3 when built against an OpenSSL that supports AES-GCM.

IMPACT:

A remote authenticated attacker could exploit this vulnerability to execute arbitrary code in the security context of the authenticated user and may therefore allow bypassing restricted shell/command configurations.

SOLUTION:

Update to [OpenSSH 6.4](#) to remediate this vulnerability.

Workaround:

A workaround, customers may disable AES-GCM in the server configuration. The following sshd_config option will disable AES-GCM while leaving other ciphers active: Ciphers aes128-ctr,aes192-ctr,aes256-ctr,aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,aes192-cbc,aes256-cbc

Patch:

Following are links for downloading patches to fix the vulnerabilities:

[OpenSSH 6.4](#)

RESULT:

SSH-2.0-OpenSSH_6.2p2 detected on port 2220 over TCP.

Oracle MySQL April 2017 Critical Patch Update (CPUAPR2017)**port 3306 / tcp****PCI COMPLIANCE STATUS**

PCI Severity Level:

MED

FAIL

Automatic Failure: Open access to databases from the Internet

VULNERABILITY DETAILS

CVSS Base Score: 5 AV:N/AC:L/Au:N/C:N/I:N/A:P
CVSS Temporal Score: 3.9 E:POC/RL:OF/RC:C
Severity: 4 
QID: 20037
Category: Database

CVE ID: [CVE-2017-3302](#), [CVE-2017-3305](#), [CVE-2017-3308](#), [CVE-2017-3309](#), [CVE-2017-3329](#), [CVE-2017-3331](#), [CVE-2017-3450](#), [CVE-2017-3452](#), [CVE-2017-3453](#), [CVE-2017-3454](#), [CVE-2017-3455](#), [CVE-2017-3456](#), [CVE-2017-3457](#), [CVE-2017-3458](#), [CVE-2017-3459](#), [CVE-2017-3460](#), [CVE-2017-3461](#), [CVE-2017-3462](#), [CVE-2017-3463](#), [CVE-2017-3464](#), [CVE-2017-3465](#), [CVE-2017-3467](#), [CVE-2017-3468](#), [CVE-2017-3599](#), [CVE-2017-3600](#)

Vendor Reference: [MySQL CPU April 2017](#)

Bugtraq ID: -

Last Update: 2017-04-19 09:36:13.0

THREAT:

This Critical Patch Update contains 25 new security fixes for Oracle MySQL.

Affected Versions:

MySQL Server, versions 5.5.54 and prior, 5.6.35 and prior, 5.7.17 and prior

IMPACT:

Successful exploitation could allow an attacker to affect the confidentiality, integrity and availability of data on the target system.

SOLUTION:

Refer to vendor advisory [Oracle MySQL April 2017](#).

Patch:

Following are links for downloading patches to fix the vulnerabilities:

[Oracle MySQL April 2017](#)

RESULT:

Vulnerable MySQL server detected: 5.5.47-0+deb7u1-log

OpenSSH Xauth Command Injection Vulnerability

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

FAIL

VULNERABILITY DETAILS

CVSS Base Score: **5.5** AV:N/AC:L/Au:S/C:P/I:P/A:N

CVSS Temporal Score: **4.3** E:POC/RL:OF/RC:C

Severity: **3** 

QID: 38623

Category: General remote services

CVE ID: [CVE-2016-3115](#)

Vendor Reference: [OpenSSH 7.2p2](#)

Bugtraq ID: -

Last Update: 2016-09-28 03:30:20.0

THREAT:

OpenSSH (OpenBSD Secure Shell) is a set of computer programs providing encrypted communication sessions over a computer network using the SSH protocol.

The sshd server fails to validate user-supplied X11 authentication credentials when establishing an X11 forwarding session. An authenticated user may inject arbitrary xauth commands by sending an x11 channel request that includes a newline character in the x11 cookie.

Please note that Systems with X11Forwarding enabled are affected.

Affected Versions:

OpenSSH versions prior to 7.2p2

IMPACT:

An authenticated, remote attacker can exploit this vulnerability to execute arbitrary commands on the targeted system.

SOLUTION:

Users are advised to upgrade to the latest version of the software available. Refer to [OpenSSH 7.2p2 Release Notes](#) for further information.

Patch:

Following are links for downloading patches to fix the vulnerabilities:

[OpenSSH 7.2p2](#)

RESULT:

SSH-2.0-OpenSSH_6.2p2 detected on port 2220 over TCP.

OpenSSH "child_set_env()" Security Bypass Issue

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

FAIL

VULNERABILITY DETAILS

CVSS Base Score:	5.8 AV:N/AC:M/Au:N/C:P/I:P/A:N
CVSS Temporal Score:	4.3 E:U/RL:OF/RC:C
Severity:	2 
QID:	42428
Category:	General remote services
CVE ID:	CVE-2014-2532
Vendor Reference:	OpenSSH 6.6
Bugtraq ID:	-
Last Update:	2015-09-07 03:30:24.0

THREAT:

OpenSSH (OpenBSD Secure Shell) is a set of computer programs providing encrypted communication sessions over a computer network using the SSH protocol.

The security issue is caused by an error within the "child_set_env()" function (usr.bin/ssh/session.c) and can be exploited to bypass intended environment restrictions by using a substring before a wildcard character.

Affected Versions:

OpenSSH Versions prior to 6.6 are affected

IMPACT:

This issue can be exploited by malicious local users to bypass certain security restrictions.

SOLUTION:

Upgrade to OpenSSH 6.6 or later to resolve this issue. Refer to [OpenSSH 6.6 Release Notes](#) for further information.

Patch:

Following are links for downloading patches to fix the vulnerabilities:

[OpenSSH 6.6: OpenSSH](#)

RESULT:

SSH-2.0-OpenSSH_6.2p2 detected on port 2220 over TCP.

Database Instance Detected

port 3306 / tcp

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

FAIL

Automatic Failure: Open access to databases from the Internet
The vulnerability is not included in the NVD.

VULNERABILITY DETAILS

CVSS Base Score: 5 AV:N/AC:L/Au:N/C:P/I:N/A:N

CVSS Temporal Score: 3.8 E:U/RL:U/RC:UC

Severity: 2 

QID: 19568

Category: Database

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2014-07-24 03:00:42.0

THREAT:

The service detected a database installation on the target. Databases like Oracle, MS-SQL, MySQL, IBM DB2, PostGgresql, Firebird and other are detected. The database instance is listed in the result section below.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

MYSQL server instance detectedMYSQL instance detected on TCP port 3306.

Information Gathered (36)

Remote Access or Management Service Detected

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 3 

QID: 42017

Category: General remote services

CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2016-10-03 03:30:30.0

THREAT:

A remote access or remote management service was detected. If such a service is accessible to malicious users it can be used to carry different type of attacks. Malicious users could try to brute force credentials or collect additional information on the service which could enable them in crafting further attacks.

The Results section includes information on the remote access service that was found on the target.

Services like Telnet, Rlogin, SSH, windows remote desktop, pcAnywhere, Citrix Management Console, Remote Admin (RAdmin), VNC, OPENVPN and ISAKMP are checked.

IMPACT:

Consequences vary by the type of attack.

SOLUTION:

Expose the remote access or remote management services only to the system administrators or intended users of the system.

RESULT:

Service name: SSH on TCP port 2220.

SMTP Banner**port 25 / tcp****PCI COMPLIANCE STATUS****PASS****VULNERABILITY DETAILS**

Severity: 2 
QID: 74042
Category: Mail services
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2003-03-11 20:14:40.0

THREAT:

N/A

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

220 srvswbnet.securewebbilling.net ESMTP Sendmail 8.14.4/8.14.4/Debian-4+deb7u1; Mon, 26 Jun 2017 12:19:05 -0500; (No UCE/UBE) logging access from: sn047.s02.iad01.qualys.com(OK)-sn047.s02.iad01.qualys.com [64.39.99.57]

MySQL Banner**port 3306 / tcp**

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 2 

QID: 19000

Category: Database

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2015-04-29 03:30:21.0

THREAT:

N/A

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

5.5.47-0+deb7u1-log

Web Server HTTP Protocol Versions

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 2 

QID: 45266

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2017-04-24 10:47:04.0

THREAT:

This QID lists supported HTTP protocol (HTTP 1.x or HTTP 2) from remote web server.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Remote Web Server supports HTTP version 1.x on 80 port.GET / HTTP/1.1

Open RPC Services Listport 111 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	2
QID:	9
Category:	RPC
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	1999-01-01 08:00:00.0

THREAT:

A port scanner was used to draw a map of all the RPC services accessible from the Internet.

IMPACT:

Unauthorized users can subsequently test vulnerabilities related to each of the services open.

SOLUTION:

Shut down any unknown or unused service on the list. To remove all RPC services, you cannot simply filter port 111 at the firewall because port 111 (the "portmap" service) only shows which ports the RPC services are listening on. Therefore, it cannot block access to these services. Disable the RPC services at the server level because each listens on an ephemeral UDP or TCP port.

RESULT:

program	version	protocol	port	name
100000	4	tcp	111	rpcbind
100000	3	tcp	111	rpcbind
100000	2	tcp	111	rpcbind
100000	4	udp	111	rpcbind
100000	3	udp	111	rpcbind
100000	2	udp	111	rpcbind
100024	1	udp	50798	status
100024	1	tcp	57977	status

Web Server HTTP Protocol Versionsport 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 2 

QID: 45266

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2017-04-24 10:47:04.0

THREAT:

This QID lists supported HTTP protocol (HTTP 1.x or HTTP 2) from remote web server.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Remote Web Server supports HTTP version 1.x on 443 port.GET / HTTP/1.1

Operating System Detected

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 2 

QID: 45017

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2017-05-03 03:30:30.0

THREAT:

Several different techniques can be used to identify the operating system (OS) running on a host. A short description of these techniques is provided below. The specific technique used to identify the OS on this host is included in the RESULTS section of your report.

1) **TCP/IP Fingerprint:** The operating system of a host can be identified from a remote system using TCP/IP fingerprinting. All underlying operating system TCP/IP stacks have subtle differences that can be seen in their responses to specially-crafted TCP packets. According to the results of this "fingerprinting" technique, the OS version is among those listed below.

Note that if one or more of these subtle differences are modified by a firewall or a packet filtering device between the scanner and the host, the fingerprinting technique may fail. Consequently, the version of the OS may not be detected correctly. If the host is behind a proxy-type firewall, the version of the operating system detected may be that of the firewall instead of the host being scanned.

2) **NetBIOS**: Short for Network Basic Input Output System, an application programming interface (API) that augments the DOS BIOS by adding special functions for local-area networks (LANs). Almost all LANs for PCs are based on the NetBIOS. Some LAN manufacturers have even extended it, adding additional network capabilities. NetBIOS relies on a message format called Server Message Block (SMB).

3) **PHP Info**: PHP is a hypertext pre-processor, an open-source, server-side, HTML-embedded scripting language used to create dynamic Web pages. Under some configurations it is possible to call PHP functions like `phpinfo()` and obtain operating system information.

4) **SNMP**: The Simple Network Monitoring Protocol is used to monitor hosts, routers, and the networks to which they attach. The SNMP service maintains Management Information Base (MIB), a set of variables (database) that can be fetched by Managers. These include "MIB-II.system.sysDescr" for the operating system.

IMPACT:

Not applicable.

SOLUTION:

Not applicable.

RESULT:

Operating System	Technique	ID
Ubuntu / Tiny Core Linux / Linux 2.6.x	TCP/IP	U4856:
	Fingerprint	25

Web Server Supports HTTP Request Pipelining

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	86565
Category:	Web server
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2005-02-23 00:25:38.0

THREAT:

Version 1.1 of the HTTP protocol supports URL-Request Pipelining. This means that instead of using the "Keep-Alive" method to keep the TCP connection alive over multiple requests, the protocol allows multiple HTTP URL requests to be made in the same TCP packet. Any Web server which is HTTP 1.1 compliant should then process all the URLs requested in the single TCP packet and respond as usual.

The target Web server was found to support this functionality of the HTTP 1.1 protocol.

IMPACT:

Support for URL-Request Pipelining has interesting consequences. For example, as explained in [this paper by Daniel Roelker](#), it can be used for evading detection by Intrusion Detection Systems. Also, it can be used in HTTP Response-Splitting style attacks.

SOLUTION:

N/A

RESULT:

GET / HTTP/1.1
Host:75.126.159.2:80

GET /Q_Evasive/ HTTP/1.1
Host:75.126.159.2:80

HTTP/1.1 403 Forbidden
Date: Mon, 26 Jun 2017 17:28:44 GMT
Server: Apache
Vary: Accept-Encoding
Content-Length: 264
Content-Type: text/html; charset=iso-8859-1

```
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don&apos;t have permission to access /
on this server.</p>
<hr>
<address>Apache Server at 75.126.159.2 Port 80</address>
</body></html>
```

HTTP/1.1 404 Not Found
Date: Mon, 26 Jun 2017 17:28:44 GMT
Server: Apache
Vary: Accept-Encoding
Content-Length: 270
Content-Type: text/html; charset=iso-8859-1

```
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /Q_Evasive/ was not found on this server.</p>
<hr>
<address>Apache Server at 75.126.159.2 Port 80</address>
</body></html>
```

Web Server Version

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 86000

Category: Web server

CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2016-10-26 03:30:31.0

THREAT:

N/A

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Server	Server
Version	Banner
Apache	Apache

Scan Diagnostics

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 150021

Category: Web Application

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2009-01-16 18:02:19.0

THREAT:

This check provides various details of the scan's performance and behavior. In some cases, this check can be used to identify problems that the scanner encountered when crawling the target Web application.

IMPACT:

The scan diagnostics data provides technical details about the crawler's performance and behavior. This information does not necessarily imply problems with the Web application.

SOLUTION:

No action is required.

RESULT:

Collected 1 links overall.

Path manipulation: Estimated requests (payloads x links): files with extension:(0 x 0) + files:(0 x 0) + directories:(9 x 1) + paths:(0 x 1) = total (9)

Batch #0 WS Directory Path manipulation: estimated time < 1 minute (9 tests, 1 inputs)

WS Directory Path manipulation: 9 vulnsigs tests, completed 9 requests, 0 seconds. Completed 9 requests of 9 estimated requests (100%). All tests completed.

Batch #0 WS enumeration: estimated time < 1 minute (10 tests, 1 inputs)
WS enumeration: 10 vulnsigs tests, completed 10 requests, 0 seconds. Completed 10 requests of 10 estimated requests (100%). All tests completed.
Batch #4 HTTP call manipulation: estimated time < 1 minute (33 tests, 0 inputs)
Batch #4 HTTP call manipulation: 33 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #4 File Inclusion analysis: estimated time < 1 minute (1 tests, 1 inputs)
Batch #4 File Inclusion analysis: 1 vulnsigs tests, completed 0 requests, 0 seconds. Completed 0 requests of 1 estimated requests (0%). All tests completed.
Batch #4 Cookie manipulation: estimated time < 1 minute (33 tests, 0 inputs)
Batch #4 Cookie manipulation: 33 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #4 Header manipulation: estimated time < 1 minute (33 tests, 1 inputs)
Batch #4 Header manipulation: 33 vulnsigs tests, completed 16 requests, 1 seconds. Completed 16 requests of 42 estimated requests (38.0952%). XSS optimization removed 24 links. All tests completed.
Batch #4 shell shock detector: estimated time < 1 minute (1 tests, 1 inputs)
Batch #4 shell shock detector: 1 vulnsigs tests, completed 1 requests, 0 seconds. Completed 1 requests of 1 estimated requests (100%). All tests completed.
Batch #4 shell shock detector(form): estimated time < 1 minute (1 tests, 0 inputs)
Batch #4 shell shock detector(form): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #4 httpoxy detector: estimated time < 1 minute (1 tests, 1 inputs)
Batch #4 httpoxy detector: 1 vulnsigs tests, completed 1 requests, 0 seconds. Completed 1 requests of 1 estimated requests (100%). All tests completed.
Batch #4 httpoxy detector(form): estimated time < 1 minute (1 tests, 0 inputs)
Batch #4 httpoxy detector(form): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #5 HTTP Time Bandit: estimated time < 1 minute (1 tests, 10 inputs)
Batch #5 HTTP Time Bandit: 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Path manipulation: Estimated requests (payloads x links): files with extension:(4 x 0) + files:(15 x 0) + directories:(104 x 1) + paths:(18 x 1) = total (122)
Batch #5 Path manipulation: estimated time < 1 minute (141 tests, 1 inputs)
Batch #5 Path manipulation: 141 vulnsigs tests, completed 117 requests, 0 seconds. Completed 117 requests of 122 estimated requests (95.9016%). All tests completed.
Total requests made: 172
Average server response time: 0.04 seconds
Most recent links:
First column indicates HTTP response code,
Special cases:
-TO: The request timed out
-CE: The request did not complete due to connection error):
404 http://75.126.159.2:443/.tar.gz
404 http://75.126.159.2:443/.tar.bz2
404 http://75.126.159.2:443/.gz
404 http://75.126.159.2:443/.zip
404 http://75.126.159.2:443/DisplayEnroll_style.jsp
404 http://75.126.159.2:443/info.php
404 http://75.126.159.2:443/sendRequest.jsp
404 http://75.126.159.2:443/phpinfo.php
404 http://75.126.159.2:443/system/
404 http://75.126.159.2:443/.git/config
Scan launched using PCI WAS combined mode.
HTML form authentication unavailable, no WEBAPP entry found

SSH Banner

port 2220 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 38050

Category: General remote services

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2003-02-04 17:08:00.0

THREAT:

N/A

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

SSH-2.0-OpenSSH_6.2p2

Internet Service Provider

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 45005

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2013-09-27 19:31:33.0

THREAT:

The information shown in the Result section was returned by the network infrastructure responsible for routing traffic from our cloud platform to the target network (where the scanner appliance is located).

This information was returned from: 1) the WHOIS service, or 2) the infrastructure provided by the closest gateway server to our cloud platform. If your ISP is routing traffic, your ISP's gateway server returned this information.

IMPACT:

This information can be used by malicious users to gather more information about the network infrastructure that may aid in launching further attacks against it.

SOLUTION:

N/A

RESULT:

The ISP network handle is: NET-66-228-118-0-1

ISP Network description:

SoftLayer Technologies Inc. SOFTLAYER-4-1-DAL01

SSH daemon information retrieving

port 2220 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	38047
Category:	General remote services
CVE ID:	CVE-1999-0634
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2009-04-21 18:50:05.0

THREAT:

SSH is a secure protocol, provided it is fully patched, properly configured, and uses FIPS approved algorithms.

For Red Hat ES 4:-	
SSH1 supported	yes
Supported authentication methods for SSH1	RSA,password
Supported ciphers for SSH1	3des,blowfish
SSH2 supported	yes
Supported keys exchange algorithm for SSH2	diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1,diffie-hellman-aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,arcfour,aes192-cbc,aes256-cbc,rij
Supported decryption ciphers for SSH2	aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,arcfour,aes192-cbc,aes256-cbc,rij
Supported encryption ciphers for SSH2	hmac-md5,hmac-sha1,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac
Supported decryption mac for SSH2	hmac-md5,hmac-sha1,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac
Supported encryption mac for SSH2	publickey,gssapi-with-mic,password
Supported authentication methods for SSH2	

IMPACT:

Successful exploitation allows an attacker to execute arbitrary commands on the SSH server or otherwise subvert an encrypted SSH channel with arbitrary data.

SOLUTION:

SSH version 2 is preferred over SSH version 1.

RESULT:

SSH1 supported	no
SSH2 supported	yes
Supported key exchange algorithms for SSH2	ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1,diffie-hellman-group1-sha1
Supported host key algorithms for SSH2	ssh-rsa,ssh-dss,ecdsa-sha2-nistp256

SSH2	
Supported decryption ciphers for SSH2	aes128-ctr,aes192-ctr,aes256-ctr,arcfour256,arcfour128,aes128-gcm@openssh.com,aes256-gcm@openssh.com,aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,aes192-cbc,aes256-cbc,arcfour,rijndael-cbc@lysator.liu.se
Supported encryption ciphers for SSH2	aes128-ctr,aes192-ctr,aes256-ctr,arcfour256,arcfour128,aes128-gcm@openssh.com,aes256-gcm@openssh.com,aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,aes192-cbc,aes256-cbc,arcfour,rijndael-cbc@lysator.liu.se
Supported decryption macs for SSH2	hmac-md5-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-ripemd160-etm@openssh.com,hmac-sha1-96-etm@openssh.com,hmac-md5-96-etm@openssh.com,hmac-md5,hmac-sha1,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac-md5-96
Supported encryption macs for SSH2	hmac-md5-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-ripemd160-etm@openssh.com,hmac-sha1-96-etm@openssh.com,hmac-md5-96-etm@openssh.com,hmac-md5,hmac-sha1,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac-md5-96
Supported decompression for SSH2	none,zlib@openssh.com
Supported compression for SSH2	none,zlib@openssh.com
Supported authentication methods for SSH2	publickey,password,keyboard-interactive

IP ID Values Randomness

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	82046
Category:	TCP/IP
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2006-07-27 21:45:19.0

THREAT:

The values for the identification (ID) field in IP headers in IP packets from the host are analyzed to determine how random they are. The changes between subsequent ID

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

IP ID changes observed (network order) for port 111: 00000000000000000000000000000000

Duration: 32 milli seconds

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	86000
Category:	Web server
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2016-10-26 03:30:31.0

THREAT:

N/A

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Server	Server
Version	Banner
Apache	Apache

ICMP Replies Received

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	82040
Category:	TCP/IP
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2003-01-16 20:14:30.0

THREAT:
ICMP (Internet Control and Error Message Protocol) is a protocol encapsulated in IP packets. ICMP's principal purpose is to provide a protocol layer that informs gateways of the inter-connectivity and accessibility of other gateways or hosts.

We have sent the following types of packets to trigger the host to send us ICMP replies:

- Echo Request (to trigger Echo Reply)
- Timestamp Request (to trigger Timestamp Reply)
- Address Mask Request (to trigger Address Mask Reply)
- UDP Packet (to trigger Port Unreachable Reply)
- IP Packet with Protocol >= 250 (to trigger Protocol Unreachable Reply)

Listed in the "Result" section are the ICMP replies that we have received.

IMPACT:
N/A

SOLUTION:
N/A

ICMP Reply Type	Triggered By	Additional Information
Unreachable (type=3 code=3)	UDP Port 17	Port Unreachable
Echo (type=0 code=0)	Echo Request	Echo Reply
Unreachable (type=3 code=3)	UDP Port 1015	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 666	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 80	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 33708	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 6969	Port Unreachable
Time Stamp (type=14 code=0)	Time Stamp Request	17:18:11 GMT
Unreachable (type=3 code=3)	UDP Port 17185	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 47262	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 6051	Port Unreachable
Unreachable (type=3		

code=3)	UDP Port 61358	Port Unreachable
Unreachable (type=3	IP with High	Protocol Unreachable
code=2)	Protocol	

Web Server Supports HTTP Request Pipelining

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	86565
Category:	Web server
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2005-02-23 00:25:38.0

THREAT:

Version 1.1 of the HTTP protocol supports URL-Request Pipelining. This means that instead of using the "Keep-Alive" method to keep the TCP connection alive over multiple requests, the protocol allows multiple HTTP URL requests to be made in the same TCP packet. Any Web server which is HTTP 1.1 compliant should then process all the URLs requested in the single TCP packet and respond as usual.

The target Web server was found to support this functionality of the HTTP 1.1 protocol.

IMPACT:

Support for URL-Request Pipelining has interesting consequences. For example, as explained in [this paper by Daniel Roelker](#), it can be used for evading detection by Intrusion Detection Systems. Also, it can be used in HTTP Response-Splitting style attacks.

SOLUTION:

N/A

RESULT:

GET / HTTP/1.1

Host:75.126.159.2:443

GET /Q_Evasive/ HTTP/1.1

Host:75.126.159.2:443

HTTP/1.1 403 Forbidden

Date: Mon, 26 Jun 2017 17:29:25 GMT

Server: Apache

Vary: Accept-Encoding

Content-Length: 265

Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">

```
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don&apos;t have permission to access /
on this server.</p>
<hr>
<address>Apache Server at 75.126.159.2 Port 443</address>
</body></html>

HTTP/1.1 404 Not Found
Date: Mon, 26 Jun 2017 17:29:25 GMT
Server: Apache
Vary: Accept-Encoding
Content-Length: 271
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /Q_Evasive/ was not found on this server.</p>
<hr>
<address>Apache Server at 75.126.159.2 Port 443</address>
</body></html>
```

Open TCP Services List

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	82023
Category:	TCP/IP
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2009-06-15 18:32:21.0

THREAT:
The port scanner enables unauthorized users with the appropriate tools to draw a map of all services on this host that can be accessed from the Internet. The test was carried out with a "stealth" port scanner so that the server does not log real connections.

The Results section displays the port number (Port), the default service listening on the port (IANA Assigned Ports/Services), the description of the service (Description) and the service that the scanner detected using service discovery (Service Detected).

IMPACT:
Unauthorized users can exploit this information to test vulnerabilities in each of the open services.

SOLUTION:

Shut down any unknown or unused service on the list. If you have difficulty figuring out which service is provided by which process or program, contact your provider's support team. For more information about commercial and open-source Intrusion Detection Systems available for detecting port scanners of this kind, visit the [CERT Web Site](#).

RESULT:

Port	IANA Assigned Ports /Services	Description	Service Detected	OS On Redirected Port
25	smtp	Simple Mail Transfer	smtp	
80	www	World Wide Web HTTP	http	
111	sunrpc	SUN Remote Procedure Call	rpc	
443	https	http protocol over TLS/SSL	http	
2220	ganymede	Ganymede	ssh	
3306	mysql	MySQL	mysql	
5666	unknown	unknown	unknown	
57977	unknown	unknown	rpc	

Scan Diagnostics

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	150021
Category:	Web Application
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2009-01-16 18:02:19.0

THREAT:

This check provides various details of the scan's performance and behavior. In some cases, this check can be used to identify problems that the scanner encountered when crawling the target Web application.

IMPACT:

The scan diagnostics data provides technical details about the crawler's performance and behavior. This information does not necessarily imply problems with the Web application.

SOLUTION:

No action is required.

RESULT:

Collected 1 links overall.

Path manipulation: Estimated requests (payloads x links): files with extension:(0 x 0) + files:(0 x 0) + directories:(9 x 1) + paths:(0 x 1) = total (9)

Batch #0 WS Directory Path manipulation: estimated time < 1 minute (9 tests, 1 inputs)

WS Directory Path manipulation: 9 vulnsigs tests, completed 9 requests, 0 seconds. Completed 9 requests of 9 estimated requests (100%). All tests completed.

Batch #0 WS enumeration: estimated time < 1 minute (10 tests, 1 inputs)
WS enumeration: 10 vulnsigs tests, completed 10 requests, 0 seconds. Completed 10 requests of 10 estimated requests (100%). All tests completed.
Batch #4 HTTP call manipulation: estimated time < 1 minute (33 tests, 0 inputs)
Batch #4 HTTP call manipulation: 33 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #4 File Inclusion analysis: estimated time < 1 minute (1 tests, 1 inputs)
Batch #4 File Inclusion analysis: 1 vulnsigs tests, completed 0 requests, 0 seconds. Completed 0 requests of 1 estimated requests (0%). All tests completed.
Batch #4 Cookie manipulation: estimated time < 1 minute (33 tests, 0 inputs)
Batch #4 Cookie manipulation: 33 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #4 Header manipulation: estimated time < 1 minute (33 tests, 1 inputs)
Batch #4 Header manipulation: 33 vulnsigs tests, completed 16 requests, 0 seconds. Completed 16 requests of 42 estimated requests (38.0952%). XSS optimization removed 24 links. All tests completed.
Batch #4 shell shock detector: estimated time < 1 minute (1 tests, 1 inputs)
Batch #4 shell shock detector: 1 vulnsigs tests, completed 1 requests, 0 seconds. Completed 1 requests of 1 estimated requests (100%). All tests completed.
Batch #4 shell shock detector(form): estimated time < 1 minute (1 tests, 0 inputs)
Batch #4 shell shock detector(form): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #4 httpoxy detector: estimated time < 1 minute (1 tests, 1 inputs)
Batch #4 httpoxy detector: 1 vulnsigs tests, completed 1 requests, 0 seconds. Completed 1 requests of 1 estimated requests (100%). All tests completed.
Batch #4 httpoxy detector(form): estimated time < 1 minute (1 tests, 0 inputs)
Batch #4 httpoxy detector(form): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #5 HTTP Time Bandit: estimated time < 1 minute (1 tests, 10 inputs)
Batch #5 HTTP Time Bandit: 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Path manipulation: Estimated requests (payloads x links): files with extension:(4 x 0) + files:(15 x 0) + directories:(104 x 1) + paths:(18 x 1) = total (122)
Batch #5 Path manipulation: estimated time < 1 minute (141 tests, 1 inputs)
Batch #5 Path manipulation: 141 vulnsigs tests, completed 117 requests, 1 seconds. Completed 117 requests of 122 estimated requests (95.9016%). All tests completed.
Total requests made: 172
Average server response time: 0.04 seconds
Most recent links:
First column indicates HTTP response code,
Special cases:
-TO: The request timed out
-CE: The request did not complete due to connection error):
404 http://75.126.159.2/.tar.gz
404 http://75.126.159.2/.tar
404 http://75.126.159.2/.zip
404 http://75.126.159.2/.gz
404 http://75.126.159.2/DisplayEnroll_style.jsp
404 http://75.126.159.2/sendRequest.jsp
404 http://75.126.159.2/info.php
404 http://75.126.159.2/phpinfo.php
404 http://75.126.159.2/.git/config
404 http://75.126.159.2/system/
Scan launched using PCI WAS combined mode.
HTML form authentication unavailable, no WEBAPP entry found

Apache Web Server Detected

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 86496

Category: Web server

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2016-10-03 12:30:55.0

THREAT:

Apache, the open source web server software that is developed and maintained by Apache Software Foundation is detected on the host.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Apache web server detected on port 443 - Apache

Default Web Page

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 12230

Category: CGI

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2014-06-17 18:16:06.0

THREAT:

The Result section displays the default Web page for the Web server.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

HTTP/1.1 403 Forbidden
Date: Mon, 26 Jun 2017 17:30:15 GMT
Server: Apache
Vary: Accept-Encoding
Content-Length: 287
Keep-Alive: timeout=200, max=181
Connection: Keep-Alive

Content-Type: text/html; charset=iso-8859-1

```
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access /
on this server.</p>
<hr>
<address>Apache Server at 2.9f.7e4b.ip4.static.sl-reverse.com Port 80</address>
</body></html>
```

Host Scan Time

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	45038
Category:	Information gathering
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2016-03-18 21:41:40.0

THREAT:
The Host Scan Time is the period of time it takes the scanning engine to perform the vulnerability assessment of a single target host. The Host Scan Time for this host is reported in the Result section below.

The Host Scan Time does not have a direct correlation to the Duration time as displayed in the Report Summary section of a scan results report. The Duration is the period of time it takes the service to perform a scan task. The Duration includes the time it takes the service to scan all hosts, which may involve parallel scanning. It also includes the time it takes for a scanner appliance to pick up the scan task and transfer the results back to the service's Secure Operating Center. Further, when a scan task is distributed across multiple scanners, the Duration includes the time it takes to perform parallel host scanning on all scanners.

For host running the Qualys Windows agent this QID reports the time taken by the agent to collect the host metadata used for the most recent assessment scan.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
Scan duration: 1355 seconds

Start time: Mon, Jun 26 2017, 17:18:05 GMT

End time: Mon, Jun 26 2017, 17:40:40 GMT

HTTP Methods Returned by OPTIONS Request

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 45056

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2006-01-16 22:00:56.0

THREAT:

The HTTP methods returned in response to an OPTIONS request to the Web server detected on the target host are listed.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Allow: OPTIONS,GET,HEAD,POST

List of Web Directories

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1

QID: 86672

Category: Web server

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2004-09-10 23:40:57.0

THREAT:

Based largely on the HTTP reply code, the following directories are most likely present on the host.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Directory	Source
/manual/	brute
	force
/manual/images/	brute
	force
/manual/	web page
/manual/de/	web page
/manual/en/	web page
/manual/es/	web page
/manual/fr/	web page
/manual/ja/	web page
/manual/ko/	web page
/manual/pt-br/	web page
/manual/tr/	web page
/manual/zh-cn/	web page
/manual/style/	web page
/manual/style/css/	web page
/manual/images/	web page
/manual/de/mod/	web page
/manual/de/faq/	web page
/manual/de/programs/	web page
/manual/de/misc/	web page
/manual/de/ssl/	web page
/manual/de/rewrite/	web page
/manual/de/vhosts/	web page
/manual/de/howto/	web page
/manual/de/platform/	web page
/manual/de/developer/	web page
/manual/en/mod/	web page
/manual/en/faq/	web page
/manual/en/programs/	web page
/manual/en/misc/	web page
/manual/en/ssl/	web page
/manual/en/rewrite/	web page
/manual/en/vhosts/	web page
/manual/en/howto/	web page
/manual/en/platform/	web page
/manual/en/developer/	web page
/manual/es/mod/	web page
/manual/es/faq/	web page
/manual/es/programs/	web page
/manual/es/misc/	web page
/manual/es/ssl/	web page
/manual/es/rewrite/	web page
/manual/es/vhosts/	web page
/manual/es/howto/	web page
/manual/es/platform/	web page
/manual/es/developer/	web page
/manual/fr/mod/	web page
/manual/fr/faq/	web page

/manual/fr/programs/	web page
/manual/fr/misc/	web page
/manual/fr/ssl/	web page
/manual/fr/rewrite/	web page
/manual/fr/vhosts/	web page
/manual/fr/howto/	web page
/manual/fr/platform/	web page
/manual/fr/developer/	web page
/manual/ja/mod/	web page
/manual/ja/faq/	web page
/manual/ja/programs/	web page
/manual/ja/misc/	web page
/manual/ja/ssl/	web page
/manual/ja/rewrite/	web page
/manual/ja/vhosts/	web page
/manual/ja/howto/	web page
/manual/ja/platform/	web page
/manual/ja/developer/	web page
/manual/ko/mod/	web page
/manual/ko/faq/	web page
/manual/ko/programs/	web page
/manual/ko/misc/	web page
/manual/ko/ssl/	web page
/manual/ko/rewrite/	web page
/manual/ko/vhosts/	web page
/manual/ko/howto/	web page
/manual/ko/platform/	web page
/manual/ko/developer/	web page
/manual/pt-br/mod/	web page
/manual/pt-br/faq/	web page
/manual/pt-br/programs/	web page
/manual/pt-br/misc/	web page
/manual/pt-br/ssl/	web page
/manual/pt-br/rewrite/	web page
/manual/pt-br/vhosts/	web page
/manual/pt-br/howto/	web page
/manual/pt-br/platform/	web page
/manual/pt-br/developer/	web page
/manual/tr/mod/	web page
/manual/tr/faq/	web page
/manual/tr/programs/	web page
/manual/tr/misc/	web page
/manual/tr/ssl/	web page
/manual/tr/rewrite/	web page
/manual/tr/vhosts/	web page
/manual/tr/howto/	web page
/manual/tr/platform/	web page
/manual/tr/developer/	web page
/manual/zh-cn/mod/	web page
/manual/zh-cn/faq/	web page
/manual/zh-cn	web page
/programs/	
/manual/zh-cn/misc/	web page
/manual/zh-cn/ssl/	web page
/manual/zh-cn/rewrite/	web page
/manual/zh-cn/vhosts/	web page

/manual/zh-cn/howto/	web page
/manual/zh-cn/platform/	web page
/manual/zh-cn	web page
/developer/	
/icons/	web page
/icons/small/	web page

HTTP Methods Returned by OPTIONS Request

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	45056
Category:	Information gathering
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2006-01-16 22:00:56.0

THREAT:

The HTTP methods returned in response to an OPTIONS request to the Web server detected on the target host are listed.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Allow: OPTIONS,GET,HEAD,POST

Links Crawled

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	150009

Category: Web Application
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2015-04-14 05:46:31.0

THREAT:

The list of unique links crawled and HTML forms submitted by the Web application scanner appear in the Results section. This list may contain fewer links than the maximum threshold defined at scan launch. The maximum links to crawl includes links in this list and requests for the same link made as an anonymous and authenticated user.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Duration of crawl phase (seconds): 21.00

Number of links: 1

(This number excludes form requests and links re-requested during authentication.)

<http://75.126.159.2:443/>

Host Responds to TCP SYN Packet with Other Flags On with SYN ACK

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 
QID: 82053
Category: TCP/IP
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2004-06-25 20:25:28.0

THREAT:

The host responds to a TCP SYN packet with at least one of the following flags set with a SYN ACK packet: RST, FIN, ACK, FIN|PSH.

IMPACT:

This behavior in the TCP/IP implementation may allow a remote user to potentially bypass a firewall protecting the host, as some (especially stateless) firewalls may be configured to allow all TCP packets with one of these flags set (RST, FIN, ACK, FIN|PSH) to go through without examining the packets' SYN flag.

SOLUTION:

Many operating systems are known to have this behavior.

RESULT:

Host responded to the following TCP probes to port 111 with SYN+ACK:
SYN+FIN
SYN+FIN+PSH

Default Web Page

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	12230
Category:	CGI
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2014-06-17 18:16:06.0

THREAT:

The Result section displays the default Web page for the Web server.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

HTTP/1.1 403 Forbidden
Date: Mon, 26 Jun 2017 17:25:32 GMT
Server: Apache
Vary: Accept-Encoding
Content-Length: 287
Keep-Alive: timeout=200, max=181
Connection: Keep-Alive
Content-Type: text/html; charset=iso-8859-1

```
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don&apos;t have permission to access /
on this server.</p>
<hr>
<address>Apache Server at 2.9f.7e4b.ip4.static.sl-reverse.com Port 80</address>
</body></html>
```

DNS Host Name

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 6

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 1999-01-01 08:00:00.0

THREAT:
The fully qualified domain name of this host, if it was obtained from a DNS server, is displayed in the RESULT section.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:

IP address	Host name
75.126.159.2	2.9f.7e4b.ip4.static.sl-reverse.com

Apache Web Server Detected port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 86496

Category: Web server

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2016-10-03 12:30:55.0

THREAT:

Apache, the open source web server software that is developed and maintained by Apache Software Foundation is detected on the host.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Apache web server detected on port 80 - Apache

Host Names Found

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	45039
Category:	Information gathering
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2005-02-14 21:01:44.0

THREAT:

The following host names were discovered for this computer using various methods such as DNS look up, NetBIOS query, and SQL server name query.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Host Name	Source
2.9f.7e4b.ip4.static.sl-reverse.com	FQDN

Links Crawled

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 150009

Category: Web Application

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2015-04-14 05:46:31.0

THREAT:

The list of unique links crawled and HTML forms submitted by the Web application scanner appear in the Results section. This list may contain fewer links than the maximum threshold defined at scan launch. The maximum links to crawl includes links in this list and requests for the same link made as an anonymous and authenticated user.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Duration of crawl phase (seconds): 21.00

Number of links: 1

(This number excludes form requests and links re-requested during authentication.)

<http://75.126.159.2/>

Traceroute

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 45006

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2003-05-09 18:28:51.0

THREAT:

Traceroute describes the path in realtime from the scanner to the remote host being contacted. It reports the IP addresses of all the routers in between.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Hops	IP	Round Trip Time	Probe
1	64.39.99.2	0.37ms	ICMP
2	216.52.119.193	2.90ms	ICMP
3	216.52.127.8	1.11ms	ICMP
4	64.95.158.246	0.39ms	ICMP
5	64.95.159.29	0.36ms	ICMP
6	206.126.236.185	0.47ms	ICMP
7	50.97.17.144	3.20ms	ICMP
8	50.97.17.165	13.36ms	ICMP
9	50.97.17.162	33.37ms	ICMP
10	50.97.17.57	31.10ms	ICMP
11	173.192.18.211	30.84ms	ICMP
12	66.228.118.178	34.40ms	ICMP
13	75.126.159.2	31.16ms	UDP

Degree of Randomness of TCP Initial Sequence Numbers

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	82045
Category:	TCP/IP
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2004-11-19 21:53:59.0

THREAT:

TCP Initial Sequence Numbers (ISNs) obtained in the SYNACK replies from the host are analyzed to determine how random they are. The average change between subsequent ISNs and the standard deviation from the average are displayed in the RESULT section. Also included is the degree of difficulty for exploitation of the TCP ISN generation scheme used by the host.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Average change between subsequent TCP initial sequence numbers is 1282909900 with a standard deviation of 494004498. These TCP initial sequence numbers were triggered by TCP SYN probes sent to the host at an average rate of 1/(5085 microseconds). The degree of difficulty to exploit the TCP initial sequence number generation scheme is: hard.

Open UDP Services List

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 82004

Category: TCP/IP

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2005-07-11 22:36:34.0

THREAT:
A port scanner was used to draw a map of all the UDP services on this host that can be accessed from the Internet.

Note that if the host is behind a firewall, there is a small chance that the list includes a few ports that are filtered or blocked by the firewall but are not actually open on the target host. This (false positive on UDP open ports) may happen when the firewall is configured to reject UDP packets for most (but not all) ports with an ICMP Port Unreachable packet. This may also happen when the firewall is configured to allow UDP packets for most (but not all) ports through and filter/block/drop UDP packets for only a few ports. Both cases are uncommon.

IMPACT:
Unauthorized users can exploit this information to test vulnerabilities in each of the open services.

SOLUTION:
Shut down any unknown or unused service on the list. If you have difficulty working out which service is provided by which process or program, contact your provider's support team. For more information about commercial and open-source Intrusion Detection Systems available for detecting port scanners of this kind, visit the [CERT Web site](#).

RESULT:

IANA Assigned Ports Port /Services	Description	Service Detected
111 sunrpc	SUN Remote Procedure Call	rpc udp
123 ntp	Network Time Protocol	ntp

List of Web Directoriesport 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 86672

Category: Web server

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2004-09-10 23:40:57.0

THREAT:
Based largely on the HTTP reply code, the following directories are most likely present on the host.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:

Directory	Source
/manual/	brute
	force
/manual/images/	brute
	force
/manual/	web page
/manual/de/	web page
/manual/en/	web page
/manual/es/	web page
/manual/fr/	web page
/manual/ja/	web page
/manual/ko/	web page
/manual/pt-br/	web page
/manual/tr/	web page
/manual/zh-cn/	web page
/manual/style/	web page
/manual/style/css/	web page
/manual/images/	web page
/manual/de/mod/	web page
/manual/de/faq/	web page
/manual/de/programs/	web page
/manual/de/misc/	web page
/manual/de/ssl/	web page
/manual/de/rewrite/	web page
/manual/de/vhosts/	web page
/manual/de/howto/	web page
/manual/de/platform/	web page
/manual/de/developer/	web page
/manual/en/mod/	web page
/manual/en/faq/	web page
/manual/en/programs/	web page
/manual/en/misc/	web page
/manual/en/ssl/	web page
/manual/en/rewrite/	web page
/manual/en/vhosts/	web page
/manual/en/howto/	web page
/manual/en/platform/	web page
/manual/en/developer/	web page

/manual/es/mod/	web page
/manual/es/faq/	web page
/manual/es/programs/	web page
/manual/es/misc/	web page
/manual/es/ssl/	web page
/manual/es/rewrite/	web page
/manual/es/vhosts/	web page
/manual/es/howto/	web page
/manual/es/platform/	web page
/manual/es/developer/	web page
/manual/fr/mod/	web page
/manual/fr/faq/	web page
/manual/fr/programs/	web page
/manual/fr/misc/	web page
/manual/fr/ssl/	web page
/manual/fr/rewrite/	web page
/manual/fr/vhosts/	web page
/manual/fr/howto/	web page
/manual/fr/platform/	web page
/manual/fr/developer/	web page
/manual/ja/mod/	web page
/manual/ja/faq/	web page
/manual/ja/programs/	web page
/manual/ja/misc/	web page
/manual/ja/ssl/	web page
/manual/ja/rewrite/	web page
/manual/ja/vhosts/	web page
/manual/ja/howto/	web page
/manual/ja/platform/	web page
/manual/ja/developer/	web page
/manual/ko/mod/	web page
/manual/ko/faq/	web page
/manual/ko/programs/	web page
/manual/ko/misc/	web page
/manual/ko/ssl/	web page
/manual/ko/rewrite/	web page
/manual/ko/vhosts/	web page
/manual/ko/howto/	web page
/manual/ko/platform/	web page
/manual/ko/developer/	web page
/manual/pt-br/mod/	web page
/manual/pt-br/faq/	web page
/manual/pt-br/programs/	web page
/manual/pt-br/misc/	web page
/manual/pt-br/ssl/	web page
/manual/pt-br/rewrite/	web page
/manual/pt-br/vhosts/	web page
/manual/pt-br/howto/	web page
/manual/pt-br/platform/	web page
/manual/pt-br/developer/	web page
/manual/tr/mod/	web page
/manual/tr/faq/	web page
/manual/tr/programs/	web page
/manual/tr/misc/	web page
/manual/tr/ssl/	web page
/manual/tr/rewrite/	web page

/manual/tr/vhosts/	web page
/manual/tr/howto/	web page
/manual/tr/platform/	web page
/manual/tr/developer/	web page
/manual/zh-cn/mod/	web page
/manual/zh-cn/faq/	web page
/manual/zh-cn	web page
/programs/	
/manual/zh-cn/misc/	web page
/manual/zh-cn/ssl/	web page
/manual/zh-cn/rewrite/	web page
/manual/zh-cn/vhosts/	web page
/manual/zh-cn/howto/	web page
/manual/zh-cn/platform/	web page
/manual/zh-cn	web page
/developer/	
/icons/	web page
/icons/small/	web page

75.126.159.3 (stagingsrv.trainpetdog.com,)

Linux 2.4-2.6 / Embedded Device / F5 Networks Big-IP / Linux 2.6

Vulnerabilities total:	61	Security risk:		3
------------------------	----	----------------	---	---

Vulnerabilities (13)**SSL/TLS Server supports TLSv1.0****port 443 / tcp over ssl****PCI COMPLIANCE STATUS**

PCI Severity Level:

LOW

FAIL

The vulnerability is not included in the NVD.

The vulnerability violates PCI DSS and may be a higher risk than noted in NVD.

This QID will be marked as a Fail for PCI as of November 1st, 2016 in accordance with the new PCI standards.

VULNERABILITY DETAILSCVSS Base Score: **2.6** AV:N/AC:H/Au:N/C:P/I:N/A:NCVSS Temporal Score: **2.3** E:F/RL:W/RC:CSeverity: **3**

QID: 38628

Category: General remote services

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2017-06-09 18:16:07.0

THREAT:

TLS is capable of using a multitude of ciphers (algorithms) to create the public and private key pairs. For example if TLSv1.0 uses either the RC4 stream cipher, or a block cipher in CBC mode. RC4 is known to have biases and the block cipher in CBC mode is vulnerable to the POODLE attack.

TLSv1.0, if configured to use the same cipher suites as SSLv3, includes a means by which a TLS implementation can downgrade the connection to SSL v3.0, thus weakening security.

[A POODLE-type](#) attack could also be launched directly at TLS without negotiating a downgrade.

This QID will be marked as a Fail for PCI as of May 1st, 2017 in accordance with the new standards. For existing implementations, Merchants will be able to submit a PCI False Positive / Exception Request and provide proof of their Risk Mitigation and Migration Plan, which will result in a pass for PCI up until June 30th, 2018.

Further details can be found at: [NEW PCI DSS v3.2 and Migrating from SSL and Early TLS v1.1](#)

IMPACT:

An attacker can exploit cryptographic flaws to conduct man-in-the-middle type attacks or to decryption communications.

For example: An attacker could force a downgrade from the TLS protocol to the older SSLv3.0 protocol and exploit the POODLE vulnerability, read secure communications or maliciously modify messages.

[A POODLE-type](#) attack could also be launched directly at TLS without negotiating a downgrade.

SOLUTION:

Disable the use of TLSv1.0 protocol in favor of a cryptographically stronger protocol such as TLSv1.2. The following openssl commands can be used to do a manual test: openssl s_client -connect ip:port -tls1 If the test is successful, then the target support TLSv1

RESULT:

TLSv1.0 is supported

HTTP Security Header Not Detected

port 80 / tcp

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

FAIL

The vulnerability is not included in the NVD.

VULNERABILITY DETAILS

CVSS Base Score: **4.3** AV:N/AC:M/Au:N/C:N/I:P/A:N
CVSS Temporal Score: **3.5** E:U/RL:U/RC:UR
Severity: **2** 
QID: 11827
Category: CGI
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2017-06-14 03:30:27.0

THREAT:

This QID reports the absence of the following [HTTP headers](#):

X-Frame-Options: This HTTP response header improves the protection of web applications against clickjacking attacks. Clickjacking, also known as a "UI redress attack", allows an attacker to use multiple transparent or opaque layers to trick a targeted user into clicking on a button or link on another page when they were intending to click on the the top level page.

X-XSS-Protection: This HTTP header enables the browser built-in Cross-Site Scripting (XSS) filter to prevent cross-site scripting attacks. X-XSS-Protection: 0; disables

this functionality.

X-Content-Type-Options: This HTTP header prevents attacks based on MIME-type mismatch. The only possible value is nosniff. If your server returns X-Content-Type-Options: nosniff in the response, the browser will refuse to load the styles and scripts in case they have an incorrect MIME-type.

QID Detection Logic:

This unauthenticated QID looks for the presence of the following HTTP responses:

Valid directives for X-Frame-Options are:

X-Frame-Options: DENY - The page cannot be displayed in a frame, regardless of the site attempting to do so.

X-Frame-Options: SAMEORIGIN - The page can only be displayed in a frame on the same origin as the page itself.

X-Frame-Options: ALLOW-FROM RESOURCE-URL - The page can only be displayed in a frame on the specified origin.

Valid directives for X-XSS-Protections are:

X-XSS-Protection: 1 - Enables XSS filtering (usually default in browsers). If a cross-site scripting attack is detected, the browser will sanitize the page (remove the unsafe parts).

X-XSS-Protection: 1; mode=block - Enables XSS filtering. Rather than sanitizing the page, the browser will prevent rendering of the page if an attack is detected.

X-XSS-Protection: 1; report=URI - Enables XSS filtering. If a cross-site scripting attack is detected, the browser will sanitize the page and report the violation. This uses the functionality of the CSP report-uri directive to send a report.

X-XSS-Protection HTTP: 0 disables this directive and hence is also treated as not detected.

A valid directive for X-Content-Type-Options: nosniff

IMPACT:

Depending on the vulnerability being exploited, an unauthenticated remote attacker could conduct cross-site scripting, clickjacking or MIME-type sniffing attacks.

SOLUTION:

Customers are advised to set proper [X-Frame-Options](#), [X-XSS-Protection](#) and [X-Content-Type-Options](#) HTTP response headers.

Depending on their server software, customers can set the following directives in their site configuration or Web.config files:

X-Frame-Options:

Apache: Header always append X-Frame-Options SAMEORIGIN

nginx: add_header X-Frame-Options SAMEORIGIN;

HAProxy: rspadd X-Frame-Options:\ SAMEORIGIN

IIS: <HTTPPROTOCOL><CUSTOMHEADERS><ADD NAME="X-Frame-Options" VALUE="SAMEORIGIN"></ADD></CUSTOMHEADERS></HTTPPROTOCOL>

X-XSS-Protection:

Apache: Header always set X-XSS-Protection "1; mode=block"

PHP: header("X-XSS-Protection: 1; mode=block");

X-Content-Type-Options:

Apache: Header always set X-Content-Type-Options: nosniff

RESULT:

X-Frame-Options HTTP Header missing on port 80.

GET / HTTP/1.1

Host: stagingsrv.trainpetdog.com

Connection: Keep-Alive

X-XSS-Protection HTTP Header missing on port 80.

X-Content-Type-Options HTTP Header missing on port 80.

SSL Certificate - Self-Signed Certificate

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PCI Severity Level:

HIGH

The vulnerability is not included in the NVD.

VULNERABILITY DETAILS

CVSS Base Score:	9.4 AV:N/AC:L/Au:N/C:C/I:C/A:N
CVSS Temporal Score:	6.9 E:U/RL:W/RC:UC
Severity:	2 
QID:	38169
Category:	General remote services
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2009-05-25 03:59:26.0

THREAT:

An SSL Certificate associates an entity (person, organization, host, etc.) with a Public Key. In an SSL connection, the client authenticates the remote server using the server's Certificate and extracts the Public Key in the Certificate to establish the secure connection.

The client can trust that the Server Certificate belongs the server only if it is signed by a mutually trusted third-party Certificate Authority (CA). Self-signed certificates are created generally for testing purposes or to avoid paying third-party CAs. These should not be used on any production or critical servers.

By exploiting this vulnerability, an attacker can impersonate the server by presenting a fake self-signed certificate. If the client knows that the server does not have a trusted certificate, it will accept this spoofed certificate and communicate with the remote server.

IMPACT:

By exploiting this vulnerability, an attacker can launch a man-in-the-middle attack.

SOLUTION:

Please install a server certificate signed by a trusted third-party Certificate Authority.

RESULT:

Certificate #0 CN=debian is a self signed certificate.

SSL Certificate - Signature Verification Failed Vulnerability

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PCI Severity Level:

HIGH

FAIL

The vulnerability is not included in the NVD.

VULNERABILITY DETAILS

CVSS Base Score:	9.4 AV:N/AC:L/Au:N/C:C/I:C/A:N
CVSS Temporal Score:	6.9 E:U/RL:W/RC:UC
Severity:	2 
QID:	38173
Category:	General remote services
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2009-05-23 00:02:29.0

THREAT:

An SSL Certificate associates an entity (person, organization, host, etc.) with a Public Key. In an SSL connection, the client authenticates the remote server using the server's Certificate and extracts the Public Key in the Certificate to establish the secure connection. The authentication is done by verifying that the public key in the certificate is signed by a trusted third-party Certificate Authority.

If a client is unable to verify the certificate, it can abort communication or prompt the user to continue the communication without authentication.

IMPACT:

By exploiting this vulnerability, man-in-the-middle attacks in tandem with DNS cache poisoning can occur.

Exception:

If the server communicates only with a restricted set of clients who have the server certificate or the trusted CA certificate, then the server or CA certificate may not be available publicly, and the scan will be unable to verify the signature.

SOLUTION:

Please install a server certificate signed by a trusted third-party Certificate Authority.

RESULT:

Certificate #0 CN=debian self signed certificate

Remote Management Service Accepting Unencrypted Credentials Detected

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

FAIL

The vulnerability is not included in the NVD.

VULNERABILITY DETAILS

CVSS Base Score: **4.3** AV:N/AC:M/Au:N/C:P/I:N/A:N
CVSS Temporal Score: **3.3** E:U/RL:W/RC:UR
Severity: **1** 
QID: 45242
Category: Information gathering
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2017-05-01 03:31:01.0

THREAT:

A remote management service that accepts unencrypted credentials was detected on target host.

Services like Telnet, FTP, HTTP with basic auth are checked.

IMPACT:

A malicious individual can easily intercept unencrypted passwords during transmission using a "network sniffer" and use this data to gain unauthorized access.

SOLUTION:

If possible, use alternate services that provide encryption.

Using strong cryptography, render all authentication credentials (such as passwords/phrases) unreadable during transmission.

RESULT:

Service name: FTP on TCP port 21.

SSL/TLS use of weak RC4 cipher

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PCI Severity Level: MED

PASS

ASV Score 2.6: The ASV access complexity is High for server side, because MiTM capabilities and a vulnerable client are required to exploit this vulnerability.

VULNERABILITY DETAILS

CVSS Base Score:	4.3 AV:N/AC:M/Au:N/C:P/I:N/A:N
CVSS Temporal Score:	3.7 E:POC/RL:W/RC:C
Severity:	3
QID:	38601
Category:	General remote services
CVE ID:	CVE-2013-2566 , CVE-2015-2808
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2016-01-29 19:32:26.0

THREAT:

Secure Sockets Layer (SSL v2/v3) and Transport Layer Security (TLS) protocols provide integrity, confidentiality and authenticity services to other protocols that lack these features.

SSL/TLS protocols use ciphers such as AES,DES, 3DES and RC4 to encrypt the content of the higher layer protocols and thus provide the confidentiality service. Normally the output of an encryption process is a sequence of random looking bytes. It was known that RC4 output has some bias in the output. Recently a group of researchers has discovered that the there is a stronger bias in RC4, which make statistical analysis of ciphertext more practical.

The described attack is to inject a malicious javascript into the victim's browser that would ensure that there are multiple connections being established with a target website and the same HTTP cookie is sent multiple times to the website in encrypted form. This provides the attacker a large set of ciphertext samples, that can be used for statistical analysis.

NOTE: On 3/12/15 NVD changed the CVSS v2 access complicity from high to medium. As a result Qualys revised the CVSS score to 4.3 immediately. On 5/4/15 Qualys is also revising the severity to level 3.

IMPACT:

If this attack is carried out and an HTTP cookie is recovered, then the attacker can use the cookie to impersonate the user whose cookie was recovered.

This attack is not very practical as it requires the attacker to have access to millions of samples of ciphertext, but there are certain assumptions that an attacker can make to improve the chances of recovering the cleartext from ciphertext. For examples HTTP cookies are either base64 encoded or hex digits. This information can help the attacker in their efforts to recover the cookie.

SOLUTION:

RC4 should not be used where possible. One reason that RC4 was still being used was BEAST and Lucky13 attacks against CBC mode ciphers in SSL and TLS. However, TLSv 1.2 or later address these issues.

RESULT:

CIPHER	KEY-EXCHANGE	AUTHENTICATION MAC	ENCRYPTION(KEY-STRENGTH)	GRADE
TLSv1 WITH RC4 CIPHERs IS SUPPORTED				
RC4-MD5	RSA	RSA	MD5 RC4(128)	MEDIUM
RC4-SHA	RSA	RSA	SHA1 RC4(128)	MEDIUM
ECDHE-RSA-RC4-SHA	ECDH	RSA	SHA1 RC4(128)	MEDIUM

SSLv3.0/TLSv1.0 Protocol Weak CBC Mode Server Side Vulnerability (BEAST)

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

PASS

ASV Score 2.6: The ASV access complexity is High for server side, because Javascript injection and MiTM capabilities and a vulnerable client that is not using record splitting are required to exploit this vulnerability.

VULNERABILITY DETAILS

CVSS Base Score: 4.3 AV:N/AC:M/Au:N/C:P/I:N/A:N

CVSS Temporal Score: 3.5 E:P/RL:W/RC:UR

Severity: 3 

QID: 42366

Category: General remote services

CVE ID: [CVE-2011-3389](#)

Vendor Reference: -

Bugtraq ID: -

Last Update: 2015-07-22 22:46:30.0

THREAT:

SSLv 3.0 and TLS v1.0 protocols are used to provide integrity, authenticity and privacy to other protocols such as HTTP and LDAP. They provide these services by using encryption for privacy, x509 certificates for authenticity and one-way hash functions for integrity. To encrypt data SSL and TLS can use block ciphers, which are encryption algorithms that can encrypt only a fixed block of original data to an encrypted block of the same size. Note that these ciphers will always obtain the same resulting block for the same original block of data. To achieve difference in the output the output of encryption is XORed with yet another block of the same size referred to as initialization vectors (IV). A special mode of operation for block ciphers known as CBC (cipher block chaining) uses one IV for the initial block and the result of the previous block for each subsequent block to obtain difference in the output of block cipher encryption.

In SSLv3.0 and TLSv1.0 implementation the choice CBC mode usage was poor because the entire traffic shares one CBC session with single set of initial IVs. The rest of the IV are as mentioned above results of the encryption of the previous blocks. The subsequent IV are available to the eavesdroppers. This allows an attacker with the capability to inject arbitrary traffic into the plain-text stream (to be encrypted by the client) to verify their guess of the plain-text preceding the injected block. If the attackers guess is correct then the output of the encryption will be the same for two blocks.

For low entropy data it is possible to guess the plain-text block with relatively few number of attempts. For example for data that has 1000 possibilities the number of attempts can be 500.

For more information please see [a paper by Gregory V. Bard](#).

NOTE:

The CVSS access complexity assigned by NIST to CVE-2011-3389 is 'Medium' which makes the base score 4.3. But Qualys has assigned access complexity to 'High' for server side, because Javascript injection and MiTM capabilities and a vulnerable client are required to exploit this vulnerability. Therefore the Qualys CVSS score is 2.6.

IMPACT:

Recently attacks against the web authentication cookies have been described which used this vulnerability. If the authentication cookie is guessed by the attacker then the attacker can impersonate the legitimate user on the Web site which accepts the authentication cookie.

SOLUTION:

This attack was identified in 2004 and later revisions of TLS protocol which contain a fix for this. If possible, upgrade to TLSv1.1 or TLSv1.2. If upgrading to TLSv1.1 or TLSv1.2 is not possible, then disabling CBC mode ciphers will remove the vulnerability.

Setting your SSL server to prioritize RC4 ciphers mitigates this vulnerability. Microsoft has posted information including workarounds for IIS at [KB2588513](#).

Using the following SSL configuration in Apache mitigates this vulnerability:

SSLHonorCipherOrder On

SSLCipherSuite RC4-SHA:HIGH:!ADH

Qualys SSL/TLS Deployment Best Practices can be found [here](#).

Note: RC4 recommendation is only in situations where upgrade to TLSv1.2 is not possible. RC4 in TLS v1.0 has output bias problem as described in QID 38601. Therefore it is recommended to upgrade to TLS v1.2 or later.

RESULT:		
Available non CBC cipher	Server's choice	SSL version
RC4-SHA	ECDHE-RSA-DES-CBC3-SHA	TLSv1

Birthday attacks against TLS ciphers with 64bit block size vulnerability (Sweet32)

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PCI Severity Level: MED

PASS

ASV Score 2.6 : Currently PCI DSS reference "3DES" as a valid encryption cipher. 112-bit keys are acceptable until 2030 per document NIST SP800-57 part 1 Rev 4.

VULNERABILITY DETAILS

CVSS Base Score:	5 AV:N/AC:L/Au:N/C:P/I:N/A:N
CVSS Temporal Score:	4.3 E:POC/RL:W/RC:C
Severity:	3
QID:	38657
Category:	General remote services
CVE ID:	CVE-2016-2183
Vendor Reference:	-
Bugtraq ID:	92630 , 95568
Last Update:	2017-04-28 23:32:47.0

THREAT:
Legacy block ciphers having block size of 64 bits are vulnerable to a practical collision attack when used in CBC mode. All versions of SSL/TLS protocol support cipher suites which use DES or 3DES as the symmetric encryption cipher are affected.

IMPACT:
Remote attackers can obtain cleartext data via a birthday attack against a long-duration encrypted session.

SOLUTION:
Disable and stop using DES and 3DES ciphers. The following openssl commands can be used to do a manual test: openssl s_client -connect ip:port -cipher "DES:3DES" -ssl2 openssl s_client -connect ip:port -cipher "DES:3DES" -ssl3 openssl s_client -connect ip:port -cipher "DES:3DES" -tls1 openssl s_client -connect ip:port -cipher "DES:3DES" -tls1_1 openssl s_client -connect ip:port -cipher "DES:3DES" -tls1_2 If any of these tests is successful, then the target is vulnerable to Sweet32.

RESULT:				
CIPHER	KEY-EXCHANGE	AUTHENTICATION MAC	ENCRYPTION(KEY-STRENGTH)	GRADE
TLSv1 WITH DES/3DES CIPHERS IS SUPPORTED				
DES-CBC3-SHA	RSA	RSA	SHA1 3DES(168)	MEDIUM
EDH-RSA-DES-CBC3-SHA	DH	RSA	SHA1 3DES(168)	MEDIUM
ECDHE-RSA-DES-CBC3-SHA	ECDH	RSA	SHA1 3DES(168)	MEDIUM

TCP Sequence Number Approximation Based Denial of Service

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

PASS

The vulnerability is purely a denial-of-service (DoS) vulnerability.

VULNERABILITY DETAILS

CVSS Base Score: 5 AV:N/AC:L/Au:N/C:N/I:N/A:P

CVSS Temporal Score: 4.2 E:F/RL:T/RC:C

Severity: 2 

QID: 82054

Category: TCP/IP

CVE ID: [CVE-2004-0230](#)

Vendor Reference: -

Bugtraq ID: [10183](#)

Last Update: 2010-02-03 01:08:44.0

THREAT:

TCP provides stateful communications between hosts on a network. TCP sessions are established by a three-way handshake and use random 32-bit sequence and acknowledgement numbers to ensure the validity of traffic. A vulnerability was reported that may permit TCP sequence numbers to be more easily approximated by remote attackers. This issue affects products released by multiple vendors.

The cause of the vulnerability is that affected implementations will accept TCP sequence numbers within a certain range, known as the acknowledgement range, of the expected sequence number for a packet in the session. This is determined by the TCP window size, which is negotiated during the three-way handshake for the session. Larger TCP window sizes may be set to allow for more throughput, but the larger the TCP window size, the more probable it is to guess a TCP sequence number that falls within an acceptable range. It was initially thought that guessing an acceptable sequence number was relatively difficult for most implementations given random distribution, making this type of attack impractical. However, some implementations may make it easier to successfully approximate an acceptable TCP sequence number, making these attacks possible with a number of protocols and implementations.

This is further compounded by the fact that some implementations may support the use of the TCP Window Scale Option, as described in RFC 1323, to extend the TCP window size to a maximum value of 1 billion.

This vulnerability will permit a remote attacker to inject a SYN or RST packet into the session, causing it to be reset and effectively allowing for denial of service attacks. An attacker would exploit this issue by sending a packet to a receiving implementation with an approximated sequence number and a forged source IP address and TCP port.

There are a few factors that may present viable target implementations, such as those which depend on long-lived TCP connections, those that have known or easily guessed IP address endpoints and those implementations with easily guessed TCP source ports. It has been noted that Border Gateway Protocol (BGP) is reported to be particularly vulnerable to this type of attack, due to the use of long-lived TCP sessions and the possibility that some implementations may use the TCP Window Scale Option. As a result, this issue is likely to affect a number of routing platforms.

Another factor to consider is the relative difficulty of injecting packets into TCP sessions, as a number of receiving implementations will reassemble packets in order, dropping any duplicates. This may make some implementations more resistant to attacks than others.

It should be noted that while a number of vendors have confirmed this issue in various products, investigations are ongoing and it is likely that many other vendors and products will turn out to be vulnerable as the issue is investigated further.

IMPACT:

Successful exploitation of this issue could lead to denial of service attacks on the TCP based services of target hosts.

SOLUTION:

Please first check the results section below for the port number on which this vulnerability was detected. If that port number is known to be used for port-forwarding, then it is the backend host that is really vulnerable.

Various implementations and products including Check Point, Cisco, Cray Inc, Hitachi, Internet Initiative Japan, Inc (IIJ), Juniper Networks, NEC, Polycom, and Yamaha are currently undergoing review. Contact the vendors to obtain more information about affected products and fixes. [NISCC Advisory 236929 - Vulnerability Issues in TCP](#) details the vendor patch status as of the time of the advisory, and identifies resolutions and workarounds.

Refer to [US-CERT Vulnerability Note VU#415294](#) and [OSVDB Article 4030](#) to obtain a list of vendors affected by this issue and a note on resolutions (if any) provided by the vendor.

For Microsoft: Refer to [MS05-019](#) and [MS06-064](#) for further details.

For SGI IRIX: Refer to [SGI Security Advisory 20040905-01-P](#)

For SCO UnixWare 7.1.3 and 7.1.1: Refer to [SCO Security Advisory SCOSA-2005.14](#)

For Solaris (Sun Microsystems): The vendor has acknowledged the vulnerability; however a patch is not available. Refer to [Sun Microsystems, Inc. Information for VU#415294](#) to obtain additional details. Also, refer to [TA04-111A](#) for detailed mitigating strategies against these attacks.

For NetBSD: Refer to [NetBSD-SA2004-006](#)

For Cisco: Refer to [cisco-sa-20040420-tcp-ios.shtml](#).

For Red Hat Linux: There is no fix available.

Workaround:

The following BGP-specific workaround information has been provided.

For BGP implementations that support it, the TCP MD5 Signature Option should be enabled. Passwords that the MD5 checksum is applied to should be set to strong values and changed on a regular basis.

Secure BGP configuration instructions have been provided for Cisco and Juniper at these locations:

[Secure Cisco IOS BGP Template](#)

[JUNOS Secure BGP Template](#)

RESULT:

Tested on port 21 with an injected SYN/RST offset by 16 bytes.

Tested on port 80 with an injected SYN/RST offset by 16 bytes.

SSL Certificate - Subject Common Name Does Not Match Server FQDN**port 443 / tcp over ssl****PCI COMPLIANCE STATUS**

PCI Severity Level:

LOW

PASS

The vulnerability is not included in the NVD.

VULNERABILITY DETAILSCVSS Base Score: **2.6** AV:N/AC:H/Au:N/C:P/I:N/A:NCVSS Temporal Score: **2.1** E:U/RL:W/RC:CSeverity: **2** 

QID: 38170

Category: General remote services

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2015-08-12 17:39:01.0

THREAT:

An SSL Certificate associates an entity (person, organization, host, etc.) with a Public Key. In an SSL connection, the client authenticates the remote server using the server's Certificate and extracts the Public Key in the Certificate to establish the secure connection.

A certificate whose Subject commonName or subjectAltName does not match the server FQDN offers only encryption without authentication.

Please note that a false positive reporting of this vulnerability is possible in the following case:

If the common name of the certificate uses a wildcard such as *.somedomainname.com and the reverse DNS resolution of the target IP is not configured. In this case there is no way for Qualys to associate the wildcard common name to the IP. Adding a reverse DNS lookup entry to the target IP will solve this problem.

IMPACT:

A man-in-the-middle attacker can exploit this vulnerability in tandem with a DNS cache poisoning attack to lure the client to another server, and then steal all the encryption communication.

SOLUTION:

Please install a server certificate whose Subject commonName or subjectAltName matches the server FQDN.

RESULT:

Certificate #0 CN=debian (debian) doesn't resolve

Path-Based Vulnerability**port 443 / tcp****PCI COMPLIANCE STATUS**

PCI Severity Level:

LOW

PASS

The vulnerability is not included in the NVD.

VULNERABILITY DETAILS

CVSS Base Score: **2.1** AV:L/AC:L/Au:N/C:P/I:N/A:N
CVSS Temporal Score: **1.9** E:F/RL:W/RC:C
Severity: **2** 
QID: 150004
Category: Web Application
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2017-06-15 03:30:35.0

THREAT:

A potentially sensitive file, directory, or directory listing was discovered on the Web server.

IMPACT:

The contents of this file or directory may disclose sensitive information.

SOLUTION:

Verify that access to this file or directory is permitted. If necessary, remove it or apply access controls to it.

RESULT:

url: https://75.126.159.3/admin.php

Payload: @PATH@admin.php

matched: HTTP/1.1 200 OK

UDP Constant IP Identification Field Fingerprinting Vulnerability

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

PASS

ASV Score = 0. The information obtained (i.e. operating system name) is not relevant to PCI.

VULNERABILITY DETAILS

CVSS Base Score: 5 AV:N/AC:L/Au:N/C:P/I:N/A:N

CVSS Temporal Score: 4.7 E:H/RL:U/RC:UR

Severity: 2 

QID: 82024

Category: TCP/IP

CVE ID: [CVE-2002-0510](#)

Vendor Reference: -

Bugtraq ID: [4314](#)

Last Update: 2008-05-07 18:23:49.0

THREAT:

The host transmits UDP packets with a constant IP Identification field. This behavior may be exploited to discover the operating system and approximate kernel version of the vulnerable system.

Normally, the IP Identification field is intended to be a reasonably unique value, and is used to reconstruct fragmented packets. It has been reported that in some versions of the Linux kernel IP stack implementation as well as other operating systems, UDP packets are transmitted with a constant IP Identification field of 0.

IMPACT:

By exploiting this vulnerability, a malicious user can discover the operating system and approximate kernel version of the host. This information can then be used in further attacks against the host.

SOLUTION:

We are not currently aware of any fixes for this issue.

RESULT:

IP_ID=0

ICMP Timestamp Request

PCI COMPLIANCE STATUS

PCI Severity Level:

LOW

PASS

The vulnerability is purely a denial-of-service (DoS) vulnerability.

VULNERABILITY DETAILS

CVSS Base Score:

CVSS Temporal Score:

Severity: 1 

QID: 82003

Category: TCP/IP

CVE ID: [CVE-1999-0524](#)

Vendor Reference: -

Bugtraq ID: -

Last Update: 2009-04-29 03:59:17.0

THREAT:

ICMP (Internet Control and Error Message Protocol) is a protocol encapsulated in IP packets. It's principal purpose is to provide a protocol layer able to inform gateways of the inter-connectivity and accessibility of other gateways or hosts. "ping" is a well-known program for determining if a host is up or down. It uses ICMP echo packets. ICMP timestamp packets are used to synchronize clocks between hosts.

IMPACT:

Unauthorized users can obtain information about your network by sending ICMP timestamp packets. For example, the internal systems clock should not be disclosed since some internal daemons use this value to calculate ID or sequence numbers (i.e., on SunOS servers).

SOLUTION:

You can filter ICMP messages of type "Timestamp" and "Timestamp Reply" at the firewall level. Some system administrators choose to filter most types of ICMP messages for various reasons. For example, they may want to protect their internal hosts from ICMP-based Denial Of Service attacks, such as the *Ping of Death* or *Smurf* attacks.

However, you should never filter **ALL** ICMP messages, as some of them ("Don't Fragment", "Destination Unreachable", "Source Quench", etc) are necessary for proper behavior of Operating System TCP/IP stacks.

It may be wiser to contact your network consultants for advice, since this issue impacts your overall network reliability and security.

RESULT:

Timestamp of host (network byte ordering): 17:18:29 GMT

Potential Vulnerabilities (3)

OpenSSH Xauth Command Injection Vulnerability

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

FAIL

VULNERABILITY DETAILS

CVSS Base Score: 5.5 AV:N/AC:L/Au:S/C:P/I:P/A:N

CVSS Temporal Score: 4.3 E:POC/RL:OF/RC:C

Severity: 3 

QID: 38623

Category: General remote services

CVE ID: [CVE-2016-3115](#)

Vendor Reference: [OpenSSH 7.2p2](#)

Bugtraq ID: -

Last Update: 2016-09-28 03:30:20.0

THREAT:

OpenSSH (OpenBSD Secure Shell) is a set of computer programs providing encrypted communication sessions over a computer network using the SSH protocol.

The sshd server fails to validate user-supplied X11 authentication credentials when establishing an X11 forwarding session. An authenticated user may inject arbitrary xauth commands by sending an x11 channel request that includes a newline character in the x11 cookie.

Please note that Systems with X11Forwarding enabled are affected.

Affected Versions:

OpenSSH versions prior to 7.2p2

IMPACT:

An authenticated, remote attacker can exploit this vulnerability to execute arbitrary commands on the targeted system.

SOLUTION:

Users are advised to upgrade to the latest version of the software available. Refer to [OpenSSH 7.2p2 Release Notes](#) for further information.

Patch:

Following are links for downloading patches to fix the vulnerabilities:

[OpenSSH 7.2p2](#)

RESULT:

SSH-2.0-OpenSSH_7.1 detected on port 2220 over TCP.

Apache Partial HTTP Request Denial of Service Vulnerability - Zero Day

port 443 / tcp

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

PASS

The vulnerability is purely a denial-of-service (DoS) vulnerability.

VULNERABILITY DETAILS

CVSS Base Score: 5 AV:N/AC:L/Au:N/C:N/I:N/A:P

CVSS Temporal Score: 4.3 E:P/RL:U/RC:UR

Severity: 3 

QID: 86847

Category: Web server

CVE ID: [CVE-2007-6750](#)

Vendor Reference: -

Bugtraq ID: [21865](#)

Last Update: 2015-04-27 03:31:01.0

THREAT:

The Apache HTTP Server, commonly referred to as Apache is a freely available Web server.

Apache is vulnerable to a denial of service due to holding a connection open for partial HTTP requests.

Apache Versions 1.x and 2.x are vulnerable.

IMPACT:

A remote attacker can cause a denial of service against the Web server which would prevent legitimate users from accessing the site.

Denial of service tools and scripts such as Slowloris takes advantage of this vulnerability.

SOLUTION:

Patch -

There are no vendor-supplied patches available at this time.

Workaround:

- Server-specific recommendations can be found [here](#).
- Countermeasures for Apache are described [here](#).
- Reverse proxies, load balancers and iptables can help to prevent this attack from occurring.
- Adjusting the [TimeOut Directive](#) can also prevent this attack from occurring.
- A new module [mod_reqtimeout](#) has been introduced since Apache 2.2.15 to provide tools for mitigation against these forms of attack.

Also refer to [Cert Blog](#) and [Slowloris and Mitigations for Apache document](#) for further information.

RESULT:

QID: 86847 detected on port 443 over TCP - Apache 2.0

Apache Partial HTTP Request Denial of Service Vulnerability - Zero Day

port 80 / tcp

PCI COMPLIANCE STATUS

PCI Severity Level:

MED

PASS

The vulnerability is purely a denial-of-service (DoS) vulnerability.

VULNERABILITY DETAILS

CVSS Base Score:	5 AV:N/AC:L/Au:N/C:N/I:N/A:P
CVSS Temporal Score:	4.3 E:P/RL:U/RC:UR
Severity:	3 
QID:	86847
Category:	Web server
CVE ID:	CVE-2007-6750
Vendor Reference:	-
Bugtraq ID:	21865
Last Update:	2015-04-27 03:31:01.0

THREAT:

The Apache HTTP Server, commonly referred to as Apache is a freely available Web server.

Apache is vulnerable to a denial of service due to holding a connection open for partial HTTP requests.

Apache Versions 1.x and 2.x are vulnerable.

IMPACT:

A remote attacker can cause a denial of service against the Web server which would prevent legitimate users from accessing the site.

Denial of service tools and scripts such as Slowloris takes advantage of this vulnerability.

SOLUTION:

Patch -

There are no vendor-supplied patches available at this time.

Workaround:

- Server-specific recommendations can be found [here](#).
- Countermeasures for Apache are described [here](#).
- Reverse proxies, load balancers and iptables can help to prevent this attack from occurring.
- Adjusting the [TimeOut Directive](#) can also prevent this attack from occurring.

- A new module [mod_reqtimeout](#) has been introduced since Apache 2.2.15 to provide tools for mitigation against these forms of attack.

Also refer to [Cert Blog](#) and [Slowloris and Mitigations for Apache document](#) for further information.

RESULT:

QID: 86847 detected on port 80 over TCP - Apache 2.0

Information Gathered (45)

Server accepts unnecessarily large POST request body

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 3 

QID: 150086

Category: Web Application

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2011-06-02 20:47:54.0

THREAT:

Web application scanner successfully sent a POST request with content type of application/x-www-form-urlencoded and 65536 bytes length random text data. Accepting request bodies with unnecessarily large size could help attacker to use less connections to achieve Layer 7 DDoS of web server. More information can be found at the [here](#)

IMPACT:

Could result in successful application level (Layer 7) DDoS attack.

SOLUTION:

Limit the size of the request body to each form's requirements. For example, a search form with 256-char search field should not accept more than 1KB value. Server-specific details can be found [here](#).

RESULT:

Server responded 200 to unnecessarily large random request body(over 64 KB) for URL http://75.126.159.3/, significantly increasing attacker's chances to prolong slow HTTP POST attack.

Remote Access or Management Service Detected

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 3 

QID: 42017

Category: General remote services

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2016-10-03 03:30:30.0

THREAT:

A remote access or remote management service was detected. If such a service is accessible to malicious users it can be used to carry different type of attacks. Malicious users could try to brute force credentials or collect additional information on the service which could enable them in crafting further attacks.

The Results section includes information on the remote access service that was found on the target.

Services like Telnet, Rlogin, SSH, windows remote desktop, pcAnywhere, Citrix Management Console, Remote Admin (RAdmin), VNC, OPENVPN and ISAKMP are checked.

IMPACT:

Consequences vary by the type of attack.

SOLUTION:

Expose the remote access or remote management services only to the system administrators or intended users of the system.

RESULT:

Service name: FTP on TCP port 21.

Service name: SSH on TCP port 2220.

DEFLATE Data Compression Algorithm Used for HTTPS

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 3 

QID: 42416

Category: General remote services

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2013-08-10 00:02:05.0

THREAT:

HTTP data is compressed before it is sent from the server. DEFLATE data compression algorithm uses the LZ77 algorithm which takes advantage of repeated strings to more efficiently compress output.

DEFLATE data compression algorithm is prone to be unsafe as described in the BREACH attack. If an attacker can inject a string into a HTTPS response intended to match another unknown string (the target secret), they can iteratively guess the secret value by monitoring the compressed size of the responses for different guesses.

Note: The attacker needs the capability of reading responses received by the user's browser and the capability of cause the victim to send requests from their browser to perform BREACH attack.

This QID detects that the remote HTTP server is using a gzip or DEFLATE (zlib) compression format which is using DEFLATE data compression algorithm.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

HTTP/1.1 200 OK
Date: Mon, 26 Jun 2017 17:30:01 GMT
Server: Apache
Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 146
Content-Type: text/html

_1F_8B_08_00_00_00_00_00_03-NK_0E_820_14_DCs_8Aqol_DC7_DD_BB_F7_02_AD_1D(_11_I_FB_90p
{+_90_CCf_BE_19_9B_F439_1Br_DC_9CMw_F7P_AC_B9_BC_EB_C5_9A_C6:;_BBg_1A+_1A4_11_91_BD__A6_16a_C0_EC_07_A2_CF_A5_19_CD_AD,
__96_9B5_F3Y_E2_1E:d_D4_DC_EB_EA_0B_FF;
e_11_19e@X_14_92_F1_CA_A2_14E_F2_15_81_14_F8_18_19_AF_D8_A8_E7_9A9_CE_99_FDi_F7_03h4*_EF_B1

HTTP/1.1 200 OK
Date: Mon, 26 Jun 2017 17:30:16 GMT
Server: Apache
Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 146
Content-Type: text/html

FTP Server Banner

port 21 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	2
QID:	27113
Category:	File Transfer Protocol
CVE ID:	CVE-1999-0614
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	1999-01-01 08:00:00.0

THREAT:

The following message is shown to all users logging on to your FTP server, including anonymous logins if they are allowed on your server.

IMPACT:
Unauthorized users can obtain sensitive information about your server, such as the version or type of server you are running, and use this information to implement specific attacks against the server.

SOLUTION:
If possible, edit the configuration files or recompile the server to restrict the type of information disclosed.

RESULT:
220 (vsFTPD 2.3.5)

Web Server Probed For Various URL-Encoding Schemes Supported

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	2
QID:	12059
Category:	CGI
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2005-02-12 07:10:13.0

THREAT:
The target Web server was probed for various URL-encoding schemes that it supports.

Per [this paper](#) by Daniel Roelker that was presented at Defcon 11, popular Web servers like Microsoft IIS support a variety of encoding schemes for the URLs. These include Percent-escaped Hex Encoding, Double-percent Escaped Hex Encoding, Microsoft's %U Encoding, Percent-escaped 2-Byte UTF-8 Encoding, and Raw 2-Byte UTF-8 Encoding.

For a sample HTTP GET request, GET /. HTTP/1.0, the following illustrates the encoded URI under these schemes:

Percent-escaped Hex Encoding: GET /%2e HTTP/1.0
Double-percent Escaped Hex Encoding: GET /%252e HTTP/1.0
Percent-escaped 2-Byte UTF-8 Encoding: GET /%C0%AE HTTP/1.0
Raw 2-Byte UTF-8 Encoding: GET /\xC0\xAE HTTP/1.0 (Actual raw 0xC0 and 0xAE bytes)
Microsoft's %U Encoding: GET /%u002e HTTP/1.0

The supported encoding schemes are listed in the Results section.

URI encoding is relevant to Web server security since, as mentioned in the paper above, attackers could launch HTTP attacks while at the same time obfuscating the URIs to evade detection by Intrusion Detection Systems that are not capable of decoding the URIs.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
Single-%-Escaped Hex-Encoding Supported

Web Server HTTP Protocol Versions

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 2 

QID: 45266

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2017-04-24 10:47:04.0

THREAT:

This QID lists supported HTTP protocol (HTTP 1.x or HTTP 2) from remote web server.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Remote Web Server supports HTTP version 1.x on 443 port.GET / HTTP/1.1

Web Server HTTP Protocol Versions

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 2 

QID: 45266

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2017-04-24 10:47:04.0

THREAT:

This QID lists supported HTTP protocol (HTTP 1.x or HTTP 2) from remote web server.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Remote Web Server supports HTTP version 1.x on 80 port.GET / HTTP/1.1

Operating System Detected

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 2 

QID: 45017

Category: Information gathering

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2017-05-03 03:30:30.0

THREAT:

Several different techniques can be used to identify the operating system (OS) running on a host. A short description of these techniques is provided below. The specific technique used to identify the OS on this host is included in the RESULTS section of your report.

1) **TCP/IP Fingerprint:** The operating system of a host can be identified from a remote system using TCP/IP fingerprinting. All underlying operating system TCP/IP stacks have subtle differences that can be seen in their responses to specially-crafted TCP packets. According to the results of this "fingerprinting" technique, the OS version is among those listed below.

Note that if one or more of these subtle differences are modified by a firewall or a packet filtering device between the scanner and the host, the fingerprinting technique may fail. Consequently, the version of the OS may not be detected correctly. If the host is behind a proxy-type firewall, the version of the operating system detected may be that of the firewall instead of the host being scanned.

2) **NetBIOS:** Short for Network Basic Input Output System, an application programming interface (API) that augments the DOS BIOS by adding special functions for local-area networks (LANs). Almost all LANs for PCs are based on the NetBIOS. Some LAN manufacturers have even extended it, adding additional network capabilities. NetBIOS relies on a message format called Server Message Block (SMB).

3) **PHP Info:** PHP is a hypertext pre-processor, an open-source, server-side, HTML-embedded scripting language used to create dynamic Web pages. Under some configurations it is possible to call PHP functions like phpinfo() and obtain operating system information.

4) **SNMP:** The Simple Network Monitoring Protocol is used to monitor hosts, routers, and the networks to which they attach. The SNMP service maintains Management Information Base (MIB), a set of variables (database) that can be fetched by Managers. These include "MIB-II.system.sysDescr" for the operating system.

IMPACT:

Not applicable.

SOLUTION:

Not applicable.

RESULT:

Operating System	Technique	ID
Linux 2.4-2.6 / Embedded Device / F5 Networks Big-IP / Linux 2.6	TCP/IP Fingerprint	M1141:5927::21

Web Server Probed For Various URL-Encoding Schemes Supported

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	2
QID:	12059
Category:	CGI
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2005-02-12 07:10:13.0

THREAT:
The target Web server was probed for various URL-encoding schemes that it supports.

Per [this paper](#) by Daniel Roelker that was presented at Defcon 11, popular Web servers like Microsoft IIS support a variety of encoding schemes for the URLs. These include Percent-escaped Hex Encoding, Double-percent Escaped Hex Encoding, Microsoft's %U Encoding, Percent-escaped 2-Byte UTF-8 Encoding, and Raw 2-Byte UTF-8 Encoding.

For a sample HTTP GET request, GET /. HTTP/1.0, the following illustrates the encoded URI under these schemes:

Percent-escaped Hex Encoding: GET /%2e HTTP/1.0
Double-percent Escaped Hex Encoding: GET /%252e HTTP/1.0
Percent-escaped 2-Byte UTF-8 Encoding: GET /%C0%AE HTTP/1.0
Raw 2-Byte UTF-8 Encoding: GET /\xC0\xAE HTTP/1.0 (Actual raw 0xC0 and 0xAE bytes)
Microsoft's %U Encoding: GET /%u002e HTTP/1.0

The supported encoding schemes are listed in the Results section.

URI encoding is relevant to Web server security since, as mentioned in the paper above, attackers could launch HTTP attacks while at the same time obfuscating the URIs to evade detection by Intrusion Detection Systems that are not capable of decoding the URIs.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
Single-%-Escaped Hex-Encoding Supported

Web Server Version

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 
QID: 86000
Category: Web server
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2016-10-26 03:30:31.0

THREAT:
N/A

IMPACT:
N/A

SOLUTION:
N/A

RESULT:

Server	Server
Version	Banner
Apache 2.0	Apache

List of Web Directories port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 
QID: 86672
Category: Web server
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2004-09-10 23:40:57.0

THREAT:
Based largely on the HTTP reply code, the following directories are most likely present on the host.

IMPACT:
N/A

SOLUTION:

N/A

RESULT:**Directory Source**

/cgi-bin/	brute
	force
/doc/	brute
	force
/bugzilla/	brute
	force
/admin	brute
	force
/websvn/	brute
	force
/svn/	brute
	force

Open UDP Services List

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	82004
Category:	TCP/IP
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2005-07-11 22:36:34.0

THREAT:

A port scanner was used to draw a map of all the UDP services on this host that can be accessed from the Internet.

Note that if the host is behind a firewall, there is a small chance that the list includes a few ports that are filtered or blocked by the firewall but are not actually open on the target host. This (false positive on UDP open ports) may happen when the firewall is configured to reject UDP packets for most (but not all) ports with an ICMP Port Unreachable packet. This may also happen when the firewall is configured to allow UDP packets for most (but not all) ports through and filter/block/drop UDP packets for only a few ports. Both cases are uncommon.

IMPACT:

Unauthorized users can exploit this information to test vulnerabilities in each of the open services.

SOLUTION:

Shut down any unknown or unused service on the list. If you have difficulty working out which service is provided by which process or program, contact your provider's support team. For more information about commercial and open-source Intrusion Detection Systems available for detecting port scanners of this kind, visit the [CERT Web site](#).

RESULT:

Port	IANA Assigned Ports /Services	Description	Service Detected
123	ntp	Network Time Protocol	ntp

Links Crawled

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	150009
Category:	Web Application
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2015-04-14 05:46:31.0

THREAT:
The list of unique links crawled and HTML forms submitted by the Web application scanner appear in the Results section. This list may contain fewer links than the maximum threshold defined at scan launch. The maximum links to crawl includes links in this list and requests for the same link made as an anonymous and authenticated user.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
Duration of crawl phase (seconds): 20.00
Number of links: 1
(This number excludes form requests and links re-requested during authentication.)

http://75.126.159.3/

Host Names Found

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	45039
Category:	Information gathering
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2005-02-14 21:01:44.0

THREAT:
The following host names were discovered for this computer using various methods such as DNS look up, NetBIOS query, and SQL server name query.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:

Host Name	Source
stagingsrv.trainpetdog.com	FQDN

Host Scan Time

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	45038
Category:	Information gathering
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2016-03-18 21:41:40.0

THREAT:
The Host Scan Time is the period of time it takes the scanning engine to perform the vulnerability assessment of a single target host. The Host Scan Time for this host is reported in the Result section below.

The Host Scan Time does not have a direct correlation to the Duration time as displayed in the Report Summary section of a scan results report. The Duration is the period of time it takes the service to perform a scan task. The Duration includes the time it takes the service to scan all hosts, which may involve parallel scanning. It also includes the time it takes for a scanner appliance to pick up the scan task and transfer the results back to the service's Secure Operating Center. Further, when a scan task is distributed across multiple scanners, the Duration includes the time it takes to perform parallel host scanning on all scanners.

For host running the Qualys Windows agent this QID reports the time taken by the agent to collect the host metadata used for the most recent assessment scan.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Scan duration: 1446 seconds

Start time: Mon, Jun 26 2017, 17:18:05 GMT

End time: Mon, Jun 26 2017, 17:42:11 GMT

SSL/TLS invalid protocol version tolerance

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 38597

Category: General remote services

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2016-01-29 20:01:36.0

THREAT:

SSL/TLS protocols have different version that can be supported by both the client and the server. This test attempts to send invalid protocol versions to the target in order to find out what is the target's behavior. The results section contains a table that indicates what was the target's response to each of our tests.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

my version	target version
0304	0301
0399	0301
0400	rejected
0499	rejected

List of Web Directories Requiring Authentication

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 86671

Category: Web server

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2004-09-10 23:40:09.0

THREAT:
The service has identified a list of Web directories which require authentication to access.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
Directories Requiring Authentication
/bugzilla/
/websvn/

SSH Banner port 2220 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 38050

Category: General remote services

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2003-02-04 17:08:00.0

THREAT:
N/A

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
SSH-2.0-OpenSSH_7.1

Degree of Randomness of TCP Initial Sequence Numbers

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 82045

Category: TCP/IP

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2004-11-19 21:53:59.0

THREAT:
TCP Initial Sequence Numbers (ISNs) obtained in the SYNACK replies from the host are analyzed to determine how random they are. The average change between subsequent ISNs and the standard deviation from the average are displayed in the RESULT section. Also included is the degree of difficulty for exploitation of the TCP ISN generation scheme used by the host.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
Average change between subsequent TCP initial sequence numbers is 1255070623 with a standard deviation of 601097208. These TCP initial sequence numbers were triggered by TCP SYN probes sent to the host at an average rate of 1/(5001 microseconds). The degree of difficulty to exploit the TCP initial sequence number generation scheme is: hard.

Default Web Page port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	12230
Category:	CGI
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2014-06-17 18:16:06.0

THREAT:
The Result section displays the default Web page for the Web server.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
HTTP/1.1 200 OK
Date: Mon, 26 Jun 2017 17:31:17 GMT
Server: Apache
Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT
Accept-Ranges: bytes
Content-Length: 177
Vary: Accept-Encoding
Keep-Alive: timeout=15, max=81
Connection: Keep-Alive
Content-Type: text/html

```
<html><body><h1>It works!</h1>
<p>This is the default web page for this server.</p>
<p>The web server software is running but no content has been added, yet.</p>
</body></html>
```

DNS Host Name

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	6
Category:	Information gathering
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	1999-01-01 08:00:00.0

THREAT:

The fully qualified domain name of this host, if it was obtained from a DNS server, is displayed in the RESULT section.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

IP address	Host name
75.126.159.3	stagingsrv.trainpetdog.com

Internet Service Provider

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	45005
Category:	Information gathering
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2013-09-27 19:31:33.0

THREAT:

The information shown in the Result section was returned by the network infrastructure responsible for routing traffic from our cloud platform to the target network (where the scanner appliance is located).

This information was returned from: 1) the WHOIS service, or 2) the infrastructure provided by the closest gateway server to our cloud platform. If your ISP is routing traffic, your ISP's gateway server returned this information.

IMPACT:

This information can be used by malicious users to gather more information about the network infrastructure that may aid in launching further attacks against it.

SOLUTION:

N/A

RESULT:

The ISP network handle is: NET-66-228-118-0-1

ISP Network description:

SoftLayer Technologies Inc. SOFTLAYER-4-1-DAL01

SSL Server Information Retrieval

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1
QID: 38116
Category: General remote services
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2016-05-24 21:02:48.0

THREAT:

The following is a list of supported SSL ciphers.

Note: If a cipher is included in this list it means that it was possible to establish a SSL connection using that cipher. There are some web servers setups that allow connections to be established using a LOW grade cipher, only to provide a web page stating that the URL is accessible only through a non-LOW grade cipher. In this case even though LOW grade cipher will be listed here QID 38140 will not be reported.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

CIPHER	KEY-EXCHANGE	AUTHENTICATION MAC	ENCRYPTION(KEY-STRENGTH)	GRADE
SSLv2 PROTOCOL IS DISABLED				
SSLv3 PROTOCOL IS DISABLED				
TLSv1 PROTOCOL IS ENABLED				
TLSv1	COMPRESSION METHOD	None		
RC4-MD5	RSA	RSA	MD5 RC4(128)	MEDIUM
RC4-SHA	RSA	RSA	SHA1 RC4(128)	MEDIUM
DES-CBC3-SHA	RSA	RSA	SHA1 3DES(168)	MEDIUM
EDH-RSA-DES-CBC3-SHA	DH	RSA	SHA1 3DES(168)	MEDIUM
AES128-SHA	RSA	RSA	SHA1 AES(128)	MEDIUM
DHE-RSA-AES128-SHA	DH	RSA	SHA1 AES(128)	MEDIUM
AES256-SHA	RSA	RSA	SHA1 AES(256)	HIGH
DHE-RSA-AES256-SHA	DH	RSA	SHA1 AES(256)	HIGH
CAMELLIA128-SHA	RSA	RSA	SHA1 Camellia(128)	MEDIUM
DHE-RSA-CAMELLIA128-SHA	DH	RSA	SHA1 Camellia(128)	MEDIUM
CAMELLIA256-SHA	RSA	RSA	SHA1 Camellia(256)	HIGH
DHE-RSA-CAMELLIA256-SHA	DH	RSA	SHA1 Camellia(256)	HIGH
SEED-SHA	RSA	RSA	SHA1 SEED(128)	MEDIUM
DHE-RSA-SEED-SHA	DH	RSA	SHA1 SEED(128)	MEDIUM
ECDHE-RSA-RC4-SHA	ECDH	RSA	SHA1 RC4(128)	MEDIUM
ECDHE-RSA-DES-CBC3-SHA	ECDH	RSA	SHA1 3DES(168)	MEDIUM
ECDHE-RSA-AES128-SHA	ECDH	RSA	SHA1 AES(128)	MEDIUM
ECDHE-RSA-AES256-SHA	ECDH	RSA	SHA1 AES(256)	HIGH
TLSv1.1 PROTOCOL IS DISABLED				

TLSv1.2 PROTOCOL IS
DISABLED

Scan Diagnostics

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	150021
Category:	Web Application
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2009-01-16 18:02:19.0

THREAT:

This check provides various details of the scan's performance and behavior. In some cases, this check can be used to identify problems that the scanner encountered when crawling the target Web application.

IMPACT:

The scan diagnostics data provides technical details about the crawler's performance and behavior. This information does not necessarily imply problems with the Web application.

SOLUTION:

No action is required.

RESULT:

Collected 1 links overall.

Path manipulation: Estimated requests (payloads x links): files with extension:(0 x 0) + files:(0 x 0) + directories:(9 x 1) + paths:(0 x 1) = total (9)

Batch #0 WS Directory Path manipulation: estimated time < 1 minute (9 tests, 1 inputs)

WS Directory Path manipulation: 9 vulnsigs tests, completed 9 requests, 1 seconds. Completed 9 requests of 9 estimated requests (100%). All tests completed.

Batch #0 WS enumeration: estimated time < 1 minute (10 tests, 1 inputs)

WS enumeration: 10 vulnsigs tests, completed 10 requests, 0 seconds. Completed 10 requests of 10 estimated requests (100%). All tests completed.

Batch #4 HTTP call manipulation: estimated time < 1 minute (33 tests, 0 inputs)

Batch #4 HTTP call manipulation: 33 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Batch #4 File Inclusion analysis: estimated time < 1 minute (1 tests, 1 inputs)

Batch #4 File Inclusion analysis: 1 vulnsigs tests, completed 0 requests, 0 seconds. Completed 0 requests of 1 estimated requests (0%). All tests completed.

Batch #4 Cookie manipulation: estimated time < 1 minute (33 tests, 0 inputs)

Batch #4 Cookie manipulation: 33 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Batch #4 Header manipulation: estimated time < 1 minute (33 tests, 1 inputs)

Batch #4 Header manipulation: 33 vulnsigs tests, completed 16 requests, 0 seconds. Completed 16 requests of 42 estimated requests (38.0952%). XSS optimization removed 24 links. All tests completed.

Batch #4 shell shock detector: estimated time < 1 minute (1 tests, 1 inputs)

Batch #4 shell shock detector: 1 vulnsigs tests, completed 1 requests, 0 seconds. Completed 1 requests of 1 estimated requests (100%). All tests completed.

Batch #4 shell shock detector(form): estimated time < 1 minute (1 tests, 0 inputs)

Batch #4 shell shock detector(form): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Batch #4 httpoxy detector: estimated time < 1 minute (1 tests, 1 inputs)

Batch #4 httpoxy detector: 1 vulnsigs tests, completed 1 requests, 0 seconds. Completed 1 requests of 1 estimated requests (100%). All tests completed.

Batch #4 httpoxy detector(form): estimated time < 1 minute (1 tests, 0 inputs)

Batch #4 httpoxy detector(form): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Batch #5 HTTP Time Bandit: estimated time < 1 minute (1 tests, 10 inputs)

Batch #5 HTTP Time Bandit: 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Path manipulation: Estimated requests (payloads x links): files with extension:(4 x 0) + files:(15 x 0) + directories:(104 x 1) + paths:(18 x 1) = total (122)

Batch #5 Path manipulation: estimated time < 1 minute (141 tests, 1 inputs)

Batch #5 Path manipulation: 141 vulnsigs tests, completed 117 requests, 1 seconds. Completed 117 requests of 122 estimated requests (95.9016%). All tests completed.

Total requests made: 172

Average server response time: 0.04 seconds

Most recent links:

First column indicates HTTP response code,

Special cases:

-TO: The request timed out

-CE: The request did not complete due to connection error):

404 http://75.126.159.3/.tar.gz

404 http://75.126.159.3/.tar

404 http://75.126.159.3/.zip

404 http://75.126.159.3/.gz

404 http://75.126.159.3/DisplayEnroll_style.jsp

404 http://75.126.159.3/sendRequest.jsp

404 http://75.126.159.3/phpinfo.php

404 http://75.126.159.3/info.php

404 http://75.126.159.3/.git/config

404 http://75.126.159.3/system/

Scan launched using PCI WAS combined mode.

HTML form authentication unavailable, no WEBAPP entry found

IP ID Values Randomness

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 82046

Category: TCP/IP

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2006-07-27 21:45:19.0

THREAT:

The values for the identification (ID) field in IP headers in IP packets from the host are analyzed to determine how random they are. The changes between subsequent ID values for either the network byte ordering or the host byte ordering, whichever is smaller, are displayed in the RESULT section along with the duration taken to send the probes. When incremental values are used, as is the case for TCP/IP implementation in many operating systems, these changes reflect the network load of the host at the time this test was conducted.

QID: 38609
Category: General remote services
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2015-05-26 22:09:34.0

THREAT:
Diffie-Hellman is a popular cryptographic algorithm used by SSL/TLS. - For fixed primes: 1024 and below are considered unsafe. - For variable primes: 512 is unsafe. 768 is probably mostly safe, but might not be for long. 1024 and above are considered safe.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
SSL server default to use Diffie-Hellman key exchange method with variable 2048(bits) prime

SSL Certificate - Information

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 86002
Category: Web server
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2003-01-24 01:09:39.0

THREAT:
N/A

IMPACT:
N/A

SOLUTION:
N/A

RESULT:

NAME	VALUE
(0)CERTIFICATE 0	
(0)Version	1 (0x0)
(0)Serial Number	ad:7a:4e:a3:30:b5:71:8f
(0)Signature Algorithm	sha1WithRSAEncryption
(0)ISSUER NAME	
commonName	debian

(0)SUBJECT NAME

commonName debian

(0)Valid From Apr 9 08:32:21 2012 GMT

(0)Valid Till Apr 7 08:32:21 2022 GMT

(0)Public Key
Algorithm rsaEncryption

(0)RSA Public Key (2048 bit)

(0) Public-Key: (2048 bit)

(0) Modulus:

(0) 00:ae:f3:b6:d2:38:67:4c:5e:f7:e6:23:51:8d:2d:

(0) cf:89:61:b3:30:22:51:65:28:cf:bd:3b:f7:ca:76:

(0) 9b:5b:16:08:a0:10:46:44:7f:e7:2a:06:7d:b6:6d:

(0) 6e:2e:b2:45:89:28:b6:e2:c3:d9:ac:70:01:36:1a:

(0) 98:9a:f6:b9:6d:8b:b5:44:06:e4:7d:3f:c7:04:86:

(0) d0:9d:d1:3d:93:ef:cc:fc:5d:91:9f:ae:86:3d:6a:

(0) e5:f2:0e:0d:6b:a9:27:08:78:4c:98:f9:6d:f3:2b:

(0) 87:b5:63:35:4e:6f:46:20:24:fb:bc:a3:ab:df:ef:

(0) a5:af:ed:ca:ef:ba:d0:80:8f:fa:8d:2f:01:ba:ba:

(0) 64:06:c3:d2:d9:f8:b5:9f:96:ca:7b:ee:eb:c1:2a:

(0) d6:90:39:1a:74:0c:89:84:85:47:b1:78:17:86:a6:

(0) 83:66:03:44:63:a9:8c:7a:bc:79:cb:db:40:45:83:

(0) 88:ce:cd:5d:73:11:a1:b8:36:d6:cb:bf:fa:b6:f9:

(0) 0d:13:51:86:2a:d5:4d:ac:6a:af:7a:be:4e:97:aa:

(0) 28:3b:b6:09:bc:0f:3b:47:de:8e:b2:51:f0:52:86:

(0) bf:22:a5:24:53:a2:27:af:f7:11:4a:f9:fe:10:a1:

(0) b5:67:69:db:14:c3:9a:9b:4f:97:01:f7:e1:93:1c:

(0) d9:43

(0) Exponent: 65537 (0x10001)

(0)Signature (256 octets)

(0) 64:dd:4b:a7:dc:13:30:c0:72:de:8d:f2:57:2a:3a:

(0) 87

(0) 6c:c6:33:7c:eb:a0:68:bb:ae:44:8d:de:6e:6d:2c:

(0) 37

(0) 03:ee:85:97:fc:bc:79:a1:9d:0d:c3:51:d9:6c:62:

(0) ad

(0) ac:04:c9:1f:ad:e6:1e:e6:ae:45:39:82:2b:43:54:

(0) 18

(0) 5f:a6:ae:fb:e5:40:5e:9b:67:f6:56:67:bb:ff:27:6d

(0) 6e:25:fb:7f:a4:93:38:a8:b5:7d:e0:a1:52:ac:2f:74

(0) c2:99:40:91:ac:48:67:12:e0:d3:19:9d:84:0b:42:

(0) af

(0) 3a:1d:dd:4b:c3:4d:bc:06:ef:7d:92:8f:0a:8e:64:4e

(0) 14:09:34:05:2a:e9:6f:0c:76:e2:04:59:69:f3:b6:79

(0) b3:a5:8f:8e:38:e0:1c:d4:f2:cb:36:e5:85:6b:84:ab

(0) 97:14:4e:d9:a6:14:d8:f1:db:c7:2d:eb:2c:11:0a:

(0) b3

(0) 0b:5b:96:88:f0:48:bc:83:6a:f3:c5:66:0c:47:22:4f

(0) ec:58:f0:3a:5a:1c:1e:e4:02:c8:e6:58:b4:6a:9b:

(0) ca

(0) 98:36:c0:ed:08:44:f7:86:1d:00:cd:bf:e0:27:75:1e

(0) bf:67:db:21:93:73:c2:69:aa:49:80:52:57:98:89:

(0) 8b

(0) 5d:9b:a3:a5:9b:48:f7:59:c8:51:b2:8b:e8:84:03:

(0) 9b

Traceroute

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1
QID: 45006
Category: Information gathering
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2003-05-09 18:28:51.0

THREAT:
Traceroute describes the path in realtime from the scanner to the remote host being contacted. It reports the IP addresses of all the routers in between.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:

Hops	IP	Round Trip Time	Probe
1	64.39.99.2	0.37ms	ICMP
2	216.52.119.193	8.86ms	ICMP
3	216.52.127.8	1.05ms	ICMP
4	64.95.158.246	0.57ms	ICMP
5	64.95.159.33	0.58ms	ICMP
6	206.126.236.185	0.61ms	ICMP
7	50.97.17.144	2.41ms	ICMP
8	50.97.17.165	14.01ms	UDP
9	50.97.17.162	33.12ms	ICMP
10	50.97.17.57	31.30ms	ICMP
11	173.192.18.211	30.96ms	ICMP
12	66.228.118.178	33.04ms	ICMP
13	75.126.159.3	31.17ms	UDP

Scan Diagnostics

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	150021
Category:	Web Application
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2009-01-16 18:02:19.0

THREAT:

This check provides various details of the scan's performance and behavior. In some cases, this check can be used to identify problems that the scanner encountered when crawling the target Web application.

IMPACT:

The scan diagnostics data provides technical details about the crawler's performance and behavior. This information does not necessarily imply problems with the Web application.

SOLUTION:

No action is required.

RESULT:

Collected 1 links overall.

Path manipulation: Estimated requests (payloads x links): files with extension:(0 x 0) + files:(0 x 0) + directories:(9 x 1) + paths:(0 x 1) = total (9)

Batch #0 WS Directory Path manipulation: estimated time < 1 minute (9 tests, 1 inputs)

WS Directory Path manipulation: 9 vulnsigs tests, completed 9 requests, 0 seconds. Completed 9 requests of 9 estimated requests (100%). All tests completed.

Batch #0 WS enumeration: estimated time < 1 minute (10 tests, 1 inputs)

WS enumeration: 10 vulnsigs tests, completed 10 requests, 0 seconds. Completed 10 requests of 10 estimated requests (100%). All tests completed.

Batch #4 HTTP call manipulation: estimated time < 1 minute (33 tests, 0 inputs)

Batch #4 HTTP call manipulation: 33 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Batch #4 File Inclusion analysis: estimated time < 1 minute (1 tests, 1 inputs)

Batch #4 File Inclusion analysis: 1 vulnsigs tests, completed 0 requests, 0 seconds. Completed 0 requests of 1 estimated requests (0%). All tests completed.

Batch #4 Cookie manipulation: estimated time < 1 minute (33 tests, 0 inputs)

Batch #4 Cookie manipulation: 33 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Batch #4 Header manipulation: estimated time < 1 minute (33 tests, 1 inputs)

Batch #4 Header manipulation: 33 vulnsigs tests, completed 16 requests, 1 seconds. Completed 16 requests of 42 estimated requests (38.0952%). XSS optimization removed 24 links. All tests completed.

Batch #4 shell shock detector: estimated time < 1 minute (1 tests, 1 inputs)

Batch #4 shell shock detector: 1 vulnsigs tests, completed 1 requests, 0 seconds. Completed 1 requests of 1 estimated requests (100%). All tests completed.

Batch #4 shell shock detector(form): estimated time < 1 minute (1 tests, 0 inputs)

Batch #4 shell shock detector(form): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Batch #4 httpoxy detector: estimated time < 1 minute (1 tests, 1 inputs)

Batch #4 httpoxy detector: 1 vulnsigs tests, completed 1 requests, 0 seconds. Completed 1 requests of 1 estimated requests (100%). All tests completed.

Batch #4 httpoxy detector(form): estimated time < 1 minute (1 tests, 0 inputs)

Batch #4 httpoxy detector(form): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Batch #5 HTTP Time Bandit: estimated time < 1 minute (1 tests, 10 inputs)

Batch #5 HTTP Time Bandit: 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.

Path manipulation: Estimated requests (payloads x links): files with extension:(4 x 0) + files:(15 x 0) + directories:(104 x 1) + paths:(18 x 1) = total (122)

Batch #5 Path manipulation: estimated time < 1 minute (141 tests, 1 inputs)

Batch #5 Path manipulation: 141 vulnsigs tests, completed 117 requests, 1 seconds. Completed 117 requests of 122 estimated requests (95.9016%). All tests completed.

Total requests made: 172

Average server response time: 0.05 seconds

Most recent links:

First column indicates HTTP response code,

Special cases:

-TO: The request timed out

-CE: The request did not complete due to connection error):

404 https://75.126.159.3/.tar.gz

404 https://75.126.159.3/.tar

404 https://75.126.159.3/.zip

404 https://75.126.159.3/.gz

404 https://75.126.159.3/DisplayEnroll_style.jsp

404 https://75.126.159.3/sendRequest.jsp

404 https://75.126.159.3/phpinfo.php

404 https://75.126.159.3/info.php

404 https://75.126.159.3/.git/config

404 https://75.126.159.3/system/

Scan launched using PCI WAS combined mode.

HTML form authentication unavailable, no WEBAPP entry found

SSL Session Caching Information

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	38291
Category:	General remote services
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2004-09-16 18:11:03.0

THREAT:

SSL session is a collection of security parameters that are negotiated by the SSL client and server for each SSL connection. SSL session caching is targeted to reduce the overhead of negotiations in recurring SSL connections. SSL sessions can be reused to resume an earlier connection or to establish multiple simultaneous connections. The client suggests an SSL session to be reused by identifying the session with a Session-ID during SSL handshake. If the server finds it appropriate to reuse the session, then they both proceed to secure communication with already known security parameters.

This test determines if SSL session caching is enabled on the host.

IMPACT:

SSL session caching is part of the SSL and TLS protocols and is not a security threat. The result of this test is for informational purposes only.

SOLUTION:

N/A

RESULT:

TLSv1 session caching is enabled on the target.

Web Server Supports HTTP Request Pipelining

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1 
QID:	86565
Category:	Web server
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2005-02-23 00:25:38.0

THREAT:

Version 1.1 of the HTTP protocol supports URL-Request Pipelining. This means that instead of using the "Keep-Alive" method to keep the TCP connection alive over multiple requests, the protocol allows multiple HTTP URL requests to be made in the same TCP packet. Any Web server which is HTTP 1.1 compliant should then process all the URLs requested in the single TCP packet and respond as usual.

The target Web server was found to support this functionality of the HTTP 1.1 protocol.

IMPACT:

Support for URL-Request Pipelining has interesting consequences. For example, as explained in [this paper by Daniel Roelker](#), it can be used for evading detection by Intrusion Detection Systems. Also, it can be used in HTTP Response-Splitting style attacks.

SOLUTION:

N/A

RESULT:

GET / HTTP/1.1

Host:75.126.159.3:443

GET /Q_Evasive/ HTTP/1.1

Host:75.126.159.3:443

HTTP/1.1 200 OK

Date: Mon, 26 Jun 2017 17:29:10 GMT

Server: Apache

Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT

Accept-Ranges: bytes

Content-Length: 177

Vary: Accept-Encoding

Content-Type: text/html

<html><body><h1>It works!</h1>

<p>This is the default web page for this server.</p>

<p>The web server software is running but no content has been added, yet.</p>

</body></html>

HTTP/1.1 404 Not Found

Date: Mon, 26 Jun 2017 17:29:10 GMT

Server: Apache

Vary: Accept-Encoding
Content-Length: 271
Content-Type: text/html; charset=iso-8859-1

Default Web Page port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 12230

Category: CGI

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2014-06-17 18:16:06.0

THREAT:
The Result section displays the default Web page for the Web server.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
HTTP/1.1 200 OK
Date: Mon, 26 Jun 2017 17:34:30 GMT
Server: Apache
Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT
Accept-Ranges: bytes
Content-Length: 177
Vary: Accept-Encoding
Keep-Alive: timeout=15, max=81
Connection: Keep-Alive
Content-Type: text/html

<html><body><h1>It works!</h1>
<p>This is the default web page for this server.</p>
<p>The web server software is running but no content has been added, yet.</p>
</body></html>

Web Server Supports HTTP Request Pipelining port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 86565

Category: Web server

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2005-02-23 00:25:38.0

THREAT:

Version 1.1 of the HTTP protocol supports URL-Request Pipelining. This means that instead of using the "Keep-Alive" method to keep the TCP connection alive over multiple requests, the protocol allows multiple HTTP URL requests to be made in the same TCP packet. Any Web server which is HTTP 1.1 compliant should then process all the URLs requested in the single TCP packet and respond as usual.

The target Web server was found to support this functionality of the HTTP 1.1 protocol.

IMPACT:

Support for URL-Request Pipelining has interesting consequences. For example, as explained in [this paper by Daniel Roelker](#), it can be used for evading detection by Intrusion Detection Systems. Also, it can be used in HTTP Response-Splitting style attacks.

SOLUTION:

N/A

RESULT:

GET / HTTP/1.1

Host:75.126.159.3:80

GET /Q_Evasive/ HTTP/1.1

Host:75.126.159.3:80

HTTP/1.1 200 OK

Date: Mon, 26 Jun 2017 17:30:20 GMT

Server: Apache

Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT

Accept-Ranges: bytes

Content-Length: 177

Vary: Accept-Encoding

Content-Type: text/html

<html><body><h1>It works!</h1>

<p>This is the default web page for this server.</p>

<p>The web server software is running but no content has been added, yet.</p>

</body></html>

HTTP/1.1 404 Not Found

Date: Mon, 26 Jun 2017 17:30:20 GMT

Server: Apache

Vary: Accept-Encoding

Content-Length: 270

Content-Type: text/html; charset=iso-8859-1

```
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /Q_Evasive/ was not found on this server.</p>
<hr>
<address>Apache Server at 75.126.159.3 Port 80</address>
</body></html>
```

ICMP Replies Received

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	82040
Category:	TCP/IP
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2003-01-16 20:14:30.0

THREAT:
ICMP (Internet Control and Error Message Protocol) is a protocol encapsulated in IP packets. ICMP's principal purpose is to provide a protocol layer that informs gateways of the inter-connectivity and accessibility of other gateways or hosts.

We have sent the following types of packets to trigger the host to send us ICMP replies:

- Echo Request (to trigger Echo Reply)
- Timestamp Request (to trigger Timestamp Reply)
- Address Mask Request (to trigger Address Mask Reply)
- UDP Packet (to trigger Port Unreachable Reply)
- IP Packet with Protocol >= 250 (to trigger Protocol Unreachable Reply)

Listed in the "Result" section are the ICMP replies that we have received.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:		
ICMP Reply Type	Triggered By	Additional Information
Echo (type=0 code=0)	Echo Request	Echo Reply
Unreachable (type=3 code=3)	UDP Port 17	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 1015	Port Unreachable

Unreachable (type=3 code=3)	UDP Port 666	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 52715	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 517	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 12346	Port Unreachable
Time Stamp (type=14 code=0)	Time Stamp Request	17:18:29 GMT
Unreachable (type=3 code=3)	UDP Port 3150	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 5321	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 445	Port Unreachable
Unreachable (type=3 code=3)	UDP Port 20827	Port Unreachable
Unreachable (type=3 code=2)	IP with High Protocol	Protocol Unreachable

SSH daemon information retrieving

port 2220 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	38047
Category:	General remote services
CVE ID:	CVE-1999-0634
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2009-04-21 18:50:05.0

THREAT:

SSH is a secure protocol, provided it is fully patched, properly configured, and uses FIPS approved algorithms.

For Red Hat ES 4:-	
SSH1 supported	yes
Supported authentication methods for SSH1	RSA,password
Supported ciphers for SSH1	3des,blowfish
SSH2 supported	yes
Supported keys exchange algorithm for SSH2	diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1,diffie-hellman-
Supported decryption ciphers for SSH2	aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,arcfour,aes192-cbc,aes256-cbc,rij

Supported encryption ciphers for SSH2	aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,arcfour,aes192-cbc,aes256-cbc,rij
Supported decryption mac for SSH2	hmac-md5,hmac-sha1,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac
Supported encryption mac for SSH2	hmac-md5,hmac-sha1,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac
Supported authentication methods for SSH2	publickey,gssapi-with-mic,password

IMPACT:
Successful exploitation allows an attacker to execute arbitrary commands on the SSH server or otherwise subvert an encrypted SSH channel with arbitrary data.

SOLUTION:
SSH version 2 is preferred over SSH version 1.

RESULT:	
SSH1 supported	no
SSH2 supported	yes
Supported key exchange algorithms for SSH2	curve25519-sha256@libssh.org,ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group14-sha1
Supported host key algorithms for SSH2	ssh-rsa,ecdsa-sha2-nistp256,ssh-ed25519
Supported decryption ciphers for SSH2	chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com
Supported encryption ciphers for SSH2	chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com
Supported decryption macs for SSH2	umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-sha1
Supported encryption macs for SSH2	umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-sha1
Supported decompression for SSH2	none,zlib@openssh.com
Supported compression for SSH2	none,zlib@openssh.com
Supported authentication methods for SSH2	publickey,password,keyboard-interactive

HTTP Methods Returned by OPTIONS Request

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	45056
Category:	Information gathering
CVE ID:	-

Vendor Reference: -
Bugtraq ID: -
Last Update: 2006-01-16 22:00:56.0

THREAT:

The HTTP methods returned in response to an OPTIONS request to the Web server detected on the target host are listed.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Allow: POST,OPTIONS,GET,HEAD

List of Web Directories Requiring Authentication

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 
QID: 86671
Category: Web server
CVE ID: -
Vendor Reference: -
Bugtraq ID: -
Last Update: 2004-09-10 23:40:09.0

THREAT:

The service has identified a list of Web directories which require authentication to access.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:**Directories Requiring Authentication**

/bugzilla/
/websvn/
/svn/

Web Server Unconfigured - Default Install Page Present

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	87089
Category:	Web server
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2012-04-30 22:49:06.0

THREAT:

The web server uses its default welcome page.
This may mean that the web server is not used or is not properly configured.

IMPACT:

N/A

SOLUTION:

Configure the web server to not display the default welcome page or disable the HTTP service if you do not use it.

RESULT:

HTTP/1.1 200 OK
Date: Mon, 26 Jun 2017 17:34:30 GMT
Server: Apache
Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT
Accept-Ranges: bytes
Content-Length: 177
Vary: Accept-Encoding
Keep-Alive: timeout=15, max=81
Connection: Keep-Alive
Content-Type: text/html

<html><body><h1>It works!</h1>
<p>This is the default web page for this server.</p>
<p>The web server software is running but no content has been added, yet.</p>
</body></html>

HTTP/1.1 200 OK
Date: Mon, 26 Jun 2017 17:34:31 GMT
Server: Apache
Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT
Accept-Ranges: bytes
Content-Length: 177
Vary: Accept-Encoding
Keep-Alive: timeout=15, max=99
Connection: Keep-Alive
Content-Type: text/html

<html><body><h1>It works!</h1>
<p>This is the default web page for this server.</p>

<p>The web server software is running but no content has been added, yet.</p>
</body></html>

List of Web Directories

port 80 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 86672

Category: Web server

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2004-09-10 23:40:57.0

THREAT:
Based largely on the HTTP reply code, the following directories are most likely present on the host.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:

Directory	Source
/bugzilla/	brute
	force
/websvn/	brute
	force
/svn/	brute
	force

Open TCP Services List

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 82023

Category: TCP/IP

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2009-06-15 18:32:21.0

THREAT:

The port scanner enables unauthorized users with the appropriate tools to draw a map of all services on this host that can be accessed from the Internet. The test was carried out with a "stealth" port scanner so that the server does not log real connections.

The Results section displays the port number (Port), the default service listening on the port (IANA Assigned Ports/Services), the description of the service (Description) and the service that the scanner detected using service discovery (Service Detected).

IMPACT:

Unauthorized users can exploit this information to test vulnerabilities in each of the open services.

SOLUTION:

Shut down any unknown or unused service on the list. If you have difficulty figuring out which service is provided by which process or program, contact your provider's support team. For more information about commercial and open-source Intrusion Detection Systems available for detecting port scanners of this kind, visit the [CERT Web Site](#).

RESULT:

Port	IANA Assigned Ports /Services	Description	Service Detected	OS On Redirected Port
21	ftp	File Transfer [Control]	ftp	
80	www	World Wide Web HTTP	http	
443	https	http protocol over TLS /SSL	http over ssl	
2220	ganymede	Ganymede	ssh	
5666	unknown	unknown	unknown	

Links Crawled port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 150009

Category: Web Application

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 2015-04-14 05:46:31.0

THREAT:

The list of unique links crawled and HTML forms submitted by the Web application scanner appear in the Results section. This list may contain fewer links than the maximum threshold defined at scan launch. The maximum links to crawl includes links in this list and requests for the same link made as an anonymous and authenticated user.

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Duration of crawl phase (seconds): 21.00

Number of links: 1

(This number excludes form requests and links re-requested during authentication.)

<https://75.126.159.3/>

SSL Web Server Version

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity: 1 

QID: 86001

Category: Web server

CVE ID: -

Vendor Reference: -

Bugtraq ID: -

Last Update: 1999-01-01 08:00:00.0

THREAT:

N/A

IMPACT:

N/A

SOLUTION:

N/A

RESULT:

Server	Server
Version	Banner
Apache 2.0	Apache

Web Server Unconfigured - Default Install Page Present

port 443 / tcp

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	87089
Category:	Web server
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2012-04-30 22:49:06.0

THREAT:

The web server uses its default welcome page.
This may mean that the web server is not used or is not properly configured.

IMPACT:

N/A

SOLUTION:

Configure the web server to not display the default welcome page or disable the HTTP service if you do not use it.

RESULT:

HTTP/1.1 200 OK
Date: Mon, 26 Jun 2017 17:31:17 GMT
Server: Apache
Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT
Accept-Ranges: bytes
Content-Length: 177
Vary: Accept-Encoding
Keep-Alive: timeout=15, max=81
Connection: Keep-Alive
Content-Type: text/html

```
<html><body><h1>It works!</h1>
<p>This is the default web page for this server.</p>
<p>The web server software is running but no content has been added, yet.</p>
</body></html>
```

HTTP/1.1 200 OK
Date: Mon, 26 Jun 2017 17:31:17 GMT
Server: Apache
Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT
Accept-Ranges: bytes
Content-Length: 177
Vary: Accept-Encoding
Keep-Alive: timeout=15, max=99
Connection: Keep-Alive
Content-Type: text/html

```
<html><body><h1>It works!</h1>
```

```
<p>This is the default web page for this server.</p>
<p>The web server software is running but no content has been added, yet.</p>
</body></html>
```

TLS Secure Renegotiation Extension Support Information

port 443 / tcp over ssl

PCI COMPLIANCE STATUS

PASS

VULNERABILITY DETAILS

Severity:	1
QID:	42350
Category:	General remote services
CVE ID:	-
Vendor Reference:	-
Bugtraq ID:	-
Last Update:	2016-03-21 16:40:23.0

THREAT:
Secure Socket Layer (SSL) and Transport Layer Security (TLS) renegotiation are vulnerable to an attack in which the attacker forms a TLS connection with the target server, injects content of his choice, and then splices in a new TLS connection from a client. The server treats the client's initial TLS handshake as a renegotiation and thus believes that the initial data transmitted by the attacker is from the same entity as the subsequent client data. TLS protocol was extended to cryptographically tierenegotiations to the TLS connections they are being performed over. This is referred to as TLS secure renegotiation extension. This detection determines whether the TLS secure renegotiation extension is supported by the server or not.

IMPACT:
N/A

SOLUTION:
N/A

RESULT:
TLS Secure Renegotiation Extension Status: supported.

Appendices

Hosts Scanned

75.126.159.2, 75.126.159.3

Hosts Not Alive

34.194.139.177

Option Profile

Scan

Scanned TCP Ports:	Full
Scanned UDP Ports:	Standard Scan
Scan Dead Hosts:	Off
Load Balancer Detection:	Off
Password Brute Forcing	Standard
Vulnerability Detection	Complete
Windows Authentication:	Disabled
SSH Authentication:	Disabled
Oracle Authentication:	Disabled
SNMP Authentication:	Disabled
Perform 3-way Handshake:	Off

Advanced

Hosts Discovery:	TCP Standard Scan, UDP Standard Scan, ICMP On
Ignore RST packets:	Off
Ignore firewall-generated SYN-ACK packets:	Off
Do not send ACK or SYN-ACK packets during host discovery:	Off

Report Legend

Payment Card Industry (PCI) Status

An overall PCI compliance status of PASSED indicates that all hosts in the report passed the PCI compliance standards. A PCI compliance status of PASSED for a single host/IP indicates that no vulnerabilities or potential vulnerabilities, as defined by the PCI DSS compliance standards set by the PCI Council, were detected on the host.

An overall PCI compliance status of FAILED indicates that at least one host in the report failed to meet the PCI compliance standards. A PCI compliance status of FAILED for a single host/IP indicates that at least one vulnerability or potential vulnerability, as defined by the PCI DSS compliance standards set by the PCI Council, was detected on the host.

Vulnerability Levels

A Vulnerability is a design flaw or mis-configuration which makes your network (or a host on your network) susceptible to malicious attacks from local or remote users. Vulnerabilities can exist in several areas of your network, such as in your firewalls, FTP servers, Web servers, operating systems or CGI bins. Depending on the level of the security risk, the successful exploitation of a vulnerability can vary from the disclosure of information about the host to a complete compromise of the host.

Severity	Level	Description
----------	-------	-------------

	1	Minimal	Intruders can collect information about the host (open ports, services, etc.) and may be able to use this information to find other vulnerabilities.
	2	Medium	Intruders may be able to collect sensitive information from the host, such as the precise version of software installed. With this information, intruders can easily exploit known vulnerabilities specific to software versions.
	3	Serious	Intruders may be able to gain access to specific information stored on the host, including security settings. This could result in potential misuse of the host by intruders. For example, vulnerabilities at this level may include partial disclosure of file contents, access to certain files on the host, directory browsing, disclosure of filtering rules and security mechanisms, denial of service attacks, and unauthorized use of services, such as mail-relaying.
	4	Critical	Intruders can possibly gain control of the host, or there may be potential leakage of highly sensitive information. For example, vulnerabilities at this level may include full read access to files, potential backdoors, or a listing of all the users on the host.
	5	Urgent	Intruders can easily gain control of the host, which can lead to the compromise of your entire network security. For example, vulnerabilities at this level may include full read and write access to files, remote execution of commands, and the presence of backdoors.

Severity	Level	Description
	Low	A vulnerability with a CVSS base score of 0.0 through 3.9. These vulnerabilities are not required to be fixed to pass PCI compliance.
	Medium	A vulnerability with a CVSS base score of 4.0 through 6.9. These vulnerabilities must be fixed to pass PCI compliance.
	High	A vulnerability with a CVSS base score of 7.0 through 10.0. These vulnerabilities must be fixed to pass PCI compliance.

Potential Vulnerability Levels

A potential vulnerability is one which we cannot confirm exists. The only way to verify the existence of such vulnerabilities on your network would be to perform an intrusive scan, which could result in a denial of service. This is strictly against our policy. Instead, we urge you to investigate these potential vulnerabilities further.

Severity	Level	Description
	1	Minimal
		If this vulnerability exists on your system, intruders can collect information about the host (open ports, services, etc.) and may be able to use this information to find other vulnerabilities.
	2	Medium
		If this vulnerability exists on your system, intruders may be able to collect sensitive information from the host, such as the precise version of software installed. With this information, intruders can easily exploit known vulnerabilities specific to software versions.
	3	Serious
		If this vulnerability exists on your system, intruders may be able to gain access to specific information stored on the host, including security settings. This could result in potential misuse of the host by intruders. For example, vulnerabilities at this level may include partial disclosure of file contents, access to certain files on the host, directory browsing, disclosure of filtering rules and security mechanisms, denial of service attacks, and unauthorized use of services, such as mail-relaying.
	4	Critical
		If this vulnerability exists on your system, intruders can possibly gain control of the host, or there may be potential leakage of highly sensitive information. For example, vulnerabilities at this level may include full read access to files, potential backdoors, or a listing of all the users on the host.
	5	Urgent
		If this vulnerability exists on your system, intruders can easily gain control of the host, which can lead to the compromise of your entire network security. For example, vulnerabilites at this level may include full read and write access to files, remote execution of commands, and the presence of backdoors.

Severity	Level	Description
	Low	A potential vulnerability with a CVSS base score of 0.0 through 3.9. These vulnerabilities are not required to be fixed to pass PCI compliance.
	Medium	A potential vulnerability with a CVSS base score of 4.0 through 6.9. These vulnerabilities must be fixed to pass PCI compliance.
	High	A potential vulnerability with a CVSS base score of 7.0 through 10.0. These vulnerabilities must be fixed to pass PCI compliance.

Information Gathered

Information Gathered includes visible information about the network related to the host, such as traceroute information, Internet Service Provider (ISP), or a list of reachable hosts. Information Gathered severity levels also include Network Mapping data, such as detected firewalls, SMTP banners, or a list of open TCP services.

Severity	Level	Description
	1 Minimal	Intruders may be able to retrieve sensitive information related to the host, such as open UDP and TCP services lists, and detection of firewalls.
	2 Medium	Intruders may be able to determine the operating system running on the host, and view banner versions.
	3 Serious	Intruders may be able to detect highly sensitive data, such as global system user lists.